

INFORMATIQUE • 1ÈRE C

MODULE 1 : ENVIRONNEMENT NUMÉRIQUE, SÉCURITÉ, MULTIMÉDIA ET GESTION DES DONNÉES

LEÇON N03

SÉCURITÉ INFORMATIQUE ET CYBERCRIMINALITÉ

DURÉE CONSEILLÉE : 4 H

DANS CETTE LEÇON

Cette leçon présente les concepts fondamentaux de la sécurité informatique (confidentialité, intégrité, disponibilité), définit la cybercriminalité et la cybersécurité, puis décrit les principaux actes malveillants et les techniques de protection des données et des logiciels. Elle s'achève par la gestion des profils et privilèges des utilisateurs d'un système informatique.

- À la fin de cette leçon, je sais définir la sécurité informatique et ses trois concepts fondamentaux : confidentialité, intégrité, disponibilité
- À la fin de cette leçon, je sais définir la cybercriminalité et la cybersécurité et les distinguer clairement
- À la fin de cette leçon, je sais énumérer et décrire au moins huit actes de cybercriminalité (vol d'identité, vol de mot de passe, intrusion, phishing, déni de service, ingénierie sociale, craquage de mot de passe, publication de faux documents)
- À la fin de cette leçon, je sais reconnaître une tentative d'hameçonnage ou d'ingénierie sociale dans une situation concrète
- À la fin de cette leçon, je sais décrire le rôle d'un antivirus, d'un pare-feu et d'un mot de passe dans la protection des données
- À la fin de cette leçon, je sais construire un mot de passe robuste selon des critères précis

TÉLÉCHARGE
ONBUCHGratuit • Google Play
Tuteur IA, annales,
concours, résultats

PASSE À ONBUCH+

Tous les cours signés, Tuteur IA
illimité, fiches PDF — onglet
OnBuch+ de l'app

CE COURS SIGNÉ CONTIENT

COURS

complet, illustré, pas à pas

MÉTHODES

et exercices résolus

EXERCICES

type examen + corrigés

FICHE BILAN

l'essentiel à retenir



Signé • OnBuch+

Ludovic A.
CONFORME AU PROGRAMME OFFICIEL MINESEC

OnBuch+

SOMMAIRE

- | | |
|---|----------------------------------|
| 1. Sécurité informatique : définition et piliers fondamentaux | utilisateurs |
| 2. Cybercriminalité et cybersécurité | 6. Activité d'intégration |
| 3. Quelques actes de cybercriminalité | 7. Méthodes et exercices résolus |
| 4. Techniques de protection des données et des logiciels | 8. Exercices |
| 5. Gestion des profils et privilèges des utilisateurs | 9. Corrigés des exercices |
| | 10. Fiche bilan |

OBJECTIFS DE LA LEÇON

- À la fin de cette leçon, je sais définir la sécurité informatique et ses trois concepts fondamentaux : confidentialité, intégrité, disponibilité
- À la fin de cette leçon, je sais définir la cybercriminalité et la cybersécurité et les distinguer clairement
- À la fin de cette leçon, je sais énumérer et décrire au moins huit actes de cybercriminalité (vol d'identité, vol de mot de passe, intrusion, phishing, déni de service, ingénierie sociale, craquage de mot de passe, publication de faux documents)
- À la fin de cette leçon, je sais reconnaître une tentative d'hameçonnage ou d'ingénierie sociale dans une situation concrète
- À la fin de cette leçon, je sais décrire le rôle d'un antivirus, d'un pare-feu et d'un mot de passe dans la protection des données
- À la fin de cette leçon, je sais construire un mot de passe robuste selon des critères précis
- À la fin de cette leçon, je sais distinguer les profils d'utilisateurs (super administrateur, administrateur, utilisateur standard, invité) et attribuer les privilèges appropriés
- À la fin de cette leçon, je sais proposer des mesures de protection adaptées à une situation donnée de menace informatique

PRÉREQUIS

- Notions de base sur l'ordinateur : matériel, logiciel, système d'exploitation (vues en Seconde et en début de Première)

- Notion de réseau informatique et d'Internet (Leçons 1 et 2 du Module 1)
- Notion de données, de fichiers et de comptes utilisateurs
- Utilisation courante d'un navigateur web, d'une messagerie et des réseaux sociaux

1 SÉCURITÉ INFORMATIQUE : DÉFINITION ET PILIERS FONDAMENTAUX

Mariam, élève en classe de Première à Yaoundé, reçoit un SMS : « Félicitations ! Vous avez gagné 50 000 FCFA au tirage MTN. Envoyez votre code Momo pour recevoir votre gain. » Pressée, excitée, elle répond et communique son code secret. Quelques heures plus tard, son compte Mobile Money est vidé. Comment cela a-t-il été possible ? Qui est responsable ? Et surtout, comment aurait-elle pu se protéger ? Cette situation, hélas trop fréquente dans nos quartiers, illustre brutalement la nécessité de comprendre la **sécurité informatique**. Ce n'est pas une option réservée aux experts : c'est une compétence vitale pour tout citoyen numérique. Dans cette première section, nous posons les fondations : qu'est-ce que la sécurité informatique, quels sont ses trois piliers indissociables et pourquoi une panne de courant ou une erreur de manipulation relèvent tout autant de la sécurité qu'un virus.

1.1 Qu'est-ce que la sécurité informatique ?

Avant de parler d'attaques ou de pare-feu, définissons précisément l'objet de notre étude.

DÉFINITION Sécurité informatique

La **sécurité informatique** (ou sécurité des systèmes d'information) est l'ensemble des moyens techniques (logiciels, matériel, cryptographie), organisationnels (politiques, procédures, formation) et humains (comportements, vigilance, habilitations) mis en œuvre pour protéger les **systèmes d'information** contre les menaces accidentelles (panne, incendie, erreur de saisie) ou intentionnelles (vol, sabotage, espionnage, rançongiciel).

Observation : Cette définition dépasse largement l'installation d'un antivirus. Elle englobe la gestion des sauvegardes, la formation des utilisateurs (comme Mariam), la climatisation de la salle serveur, la politique de mots de passe de l'établissement, etc.

EXEMPLE Ce que l'on protège : les quatre actifs d'un système d'information

Dans un lycée de Douala, le système d'information comprend :

- Les données (informations) : bulletins de notes, fiches de paie du personnel, base d'élèves, résultats du Probatoire. C'est l'actif le plus précieux.
- Les logiciels : le système d'exploitation (Windows Server, Ubuntu), l'application de gestion scolaire (ex. GESSCOL), le navigateur web, l'antivirus.
- Le matériel (hardware) : serveurs, ordinateurs de la salle informatique, switches, routeurs, câblage, onduleurs.
- Les services : l'accès Internet (CAMTEL fibre), le Wi-Fi administratif, le portail d'ins-

cription en ligne, la messagerie académique.
Une atteinte à l'un de ces quatre actifs compromet la sécurité globale.

1.2 Les trois piliers fondamentaux : le triptyque C-I-D

Toute politique de sécurité vise à garantir simultanément trois propriétés fondamentales. C'est le célèbre **triptique C-I-D** (Confidentialité, Intégrité, Disponibilité), appelé **CIA triad** en anglais (Confidentiality, Integrity, Availability). Un système n'est considéré comme sécurisé que s'il respecte les trois.

PROPRIÉTÉ Triptyque C-I-D — Condition de sécurité

Un système d'information est dit sécurisé s'il garantit simultanément :

1. La confidentialité : l'information n'est accessible qu'aux entités autorisées.
2. L'intégrité : l'information n'est modifiée ou détruite que par des entités autorisées et de manière contrôlée.
3. La disponibilité : l'information et les services sont accessibles et utilisables sur demande par les entités autorisées.

La faiblesse de l'un des trois piliers compromet l'ensemble.

Analysons chaque pilier en détail avec des exemples de notre contexte.

1.3 Pilier 1 — Confidentialité : « Qui a le droit de voir ? »

DÉFINITION Confidentialité

La **confidentialité** assure que les informations ne sont pas divulguées à des personnes, entités ou processus non autorisés. Elle concerne le secret des données, qu'elles soient stockées (au repos), transmises (en transit) ou traitées (en usage).

EXEMPLE Exemple de confidentialité : le dossier médical et le relevé bancaire

- Dossier médical (Hôpital Central de Yaoundé) : Seul le médecin traitant, le patient et le personnel habilité (infirmier, pharmacien) peuvent consulter le diagnostic. Un agent d'accueil ou un étudiant en stage n'y a pas accès.
- Relevé Mobile Money (MTN/Orange) : Seul le titulaire du compte (après authentification par code PIN) et les systèmes automatiques de la banque peuvent voir l'histo-

rique des transactions. Un tiers qui intercepte le SMS de notification viole la confidentialité.

Atteintes typiques : écoute réseau (sniffing), vol de mot de passe (shoulder surfing, keylogger), fuite de base de données (mauvaise configuration de serveur), phishing (hameçonnage) comme pour Mariam. **Protections** : chiffrement (AES, TLS/HTTPS), contrôle d'accès (ACL, RBAC), classification des données (secret, confidentiel, public), sensibilisation au phishing.

1.4 Pilier 2 — Intégrité : « Les données sont-elles exactes et complètes ? »

DÉFINITION Intégrité

L'**intégrité** garantit que les données n'ont pas été modifiées, corrompues ou détruites de manière non autorisée ou non détectée. Elle assure l'exactitude et la cohérence de l'information tout au long de son cycle de vie.

EXEMPLE Exemple d'intégrité : le bulletin électronique d'un élève

Imagine la base de données des notes du Lycée de Nkolbisson.

- Atteinte malveillante : Un élève (ou un tiers) pénètre le système et change sa note de 8/20 en 16/20. L'intégrité est violée.
- Atteinte accidentelle : Une coupure de courant brutale pendant l'écriture sur le disque corrompt le fichier de la classe de 1ère D. Les notes deviennent illisibles. L'intégrité est violée (corruption).
- Protection : Les systèmes de gestion de base de données (SGBD) utilisent des transactions (ACID : Atomicité, Cohérence, Isolation, Durabilité) et des empreintes cryptographiques (hash SHA-256) pour détecter toute modification non autorisée.

Atteintes typiques : modification de pages web (defacement), injection SQL, corruption de fichiers par virus, erreur de saisie humaine non contrôlée. **Protections** : sommes de contrôle (CRC, hash SHA-256), signatures numériques, contrôle de saisie (contraintes de domaine, clés étrangères), journaux d'audit (logs) immuables, sauvegardes régulières et vérifiées.

1.5 Pilier 3 — Disponibilité : « Le service marche-t-il quand j'en ai besoin ? »

DÉFINITION Disponibilité

La **disponibilité** assure que les informations, les systèmes et les réseaux sont accessibles et opérationnels au moment où les utilisateurs légitimes en ont besoin, dans des délais

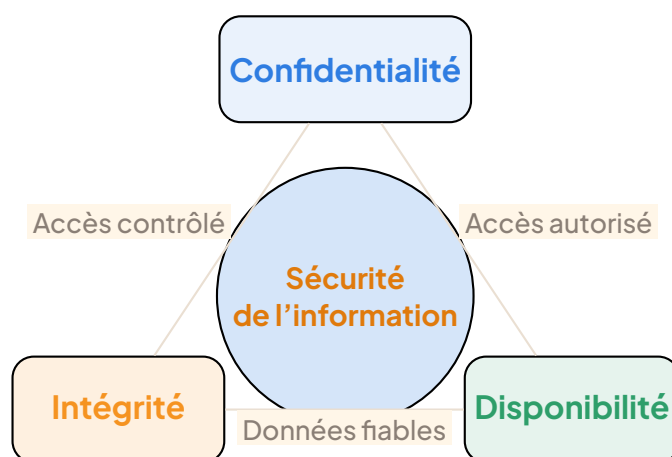
acceptables.

EXEMPLE Exemple de disponibilité : le site de l'OBC le jour des résultats

Chaque année, le site de l'Office du Baccalauréat du Cameroun (www.obbc.cm ou portails associés) subit une charge énorme le jour de la proclamation.

- Scénario nominal : Le serveur tient la charge, les élèves consultent leurs résultats en quelques secondes. Disponibilité OK.
- Atteinte (panne) : Le serveur sature (CPU 100%, RAM pleine), le site affiche « 503 Service Unavailable » ou ne répond plus. Aucun pirate n'est impliqué, c'est une défaillance de capacité. La disponibilité est violée.
- Atteinte (attaque) : Une attaque par déni de service distribué (DDoS) inonde le serveur de requêtes fictives depuis des milliers de machines zombies. Le site devient inaccessible pour les vrais élèves. Disponibilité violée intentionnellement.

Atteintes typiques : pannes matérielles (disque dur HS, alimentation), pannes logicielles (bug, boucle infinie), catastrophes (inondation serveur, incendie), attaques DDoS, rançongiciel (chiffrement des données les rendant indisponibles). **Protections** : redondance matérielle (RAID, double alimentation, cluster), sauvegardes externalisées (règle 3-2-1), onduleurs et groupes électrogènes, plans de reprise d'activité (PRA) et de continuité d'activité (PCA), anti-DDoS (Cloudflare, filtrage FAI), surveillance (monitoring) Zabbix/Nagios.



Le triptyque C-I-D (CIA triad) : les trois piliers indissociables de la sécurité de l'information.

Le schéma ci-dessus montre que la sécurité réside **au centre**, à l'intersection des trois piliers. Sacrifier l'un pour l'autre (ex. : trop de confidentialité qui bloque l'accès → perte de disponibilité) casse la sécurité.

Pilier	Définition synthétique	Exemple d'attaque (Cameroun)	Mesure de protection clé
Confidentialité	Seuls les autorisés lisent l'info.	Phishing SMS « Gain MTN » → vol code Momo → vidage compte.	Chiffrement TLS/HTTPS, MFA (double facteur), sensibilisation.
Intégrité	Données exactes, non modifiées sans droit.	Falsification notes bulletin (intrusion SGBD) ou corruption fichier (coupure courant).	Hash SHA-256, signatures numériques, transactions ACID, sauvegardes.
Disponibilité	Service accessible quand nécessaire.	Site OBC inaccessible jour résultats (surcharge ou DDoS). Rançongiciel hôpital.	Redondance (RAID, cluster), PRA/PCA, onduleur, anti-DDoS, monitoring.

1.6 Exemples concrets d'atteintes aux piliers au Cameroun

EXEMPLE Atteinte à la disponibilité : la panne du site de l'OBC

Le jour de la proclamation des résultats du Baccalauréat session 2023, le portail officiel de l'Office du Baccalauréat du Cameroun est resté inaccessible pendant plusieurs heures.

- Pilier touché : Disponibilité (les données existent, les serveurs sont intacts, mais le service ne répond pas).
- Cause probable : Pic de trafic légitime non anticipé (absence de scalabilité / montée en charge) ou attaque DDoS opportuniste.
- Conséquence : Stress massif pour des milliers de familles, rumeurs, perte de confiance dans le service public numérique.
- Leçon : La disponibilité ne s'improvise pas ; elle s'architecte (load balancing, CDN, auto-scaling cloud).

EXEMPLE Atteinte à la confidentialité : fuite de données administratives

En 2021, une base de données contenant des informations personnelles (noms, numéros CNI, affectations) d'enseignants du Ministère de l'Éducation de Base (MINEDUB) a été retrouvée en accès libre sur un serveur mal configuré (bucket S3 public ou partage réseau sans mot de passe).

- Pilier touché : Confidentialité.
- Cause : Erreur humaine de configuration (moyen organisationnel/technique), pas un virus.

- Conséquence : Risque d'usurpation d'identité, démarchage frauduleux, atteinte à la vie privée.

EXEMPLE Atteinte à l'intégrité : falsification de documents administratifs

Un réseau de faussaires à Douala produit de faux bulletins de notes et de faux diplômes du Baccalauréat en imitant la mise en page officielle, mais en modifiant les notes et les mentions. Ces documents sont vendus pour des inscriptions universitaires ou des concours de la fonction publique.

- Pilier touché : Intégrité (le document officiel est contrefait, sa valeur de vérité est détruite).
- Parade technique : Signature numérique visible (QR code vérifiable sur portail MINE-SUP/OBC), registre blockchain ou annuaire public des diplômes authentiques.

1.7 Au-delà des virus : une vision globale de la sécurité

ATTENTION Erreur fréquente : « Sécurité = Antivirus »

« J'ai un antivirus, donc je suis en sécurité. » FAUX.

- L'antivirus ne protège que contre les logiciels malveillants connus (signatures) ou suspects (heuristique). Il ne protège pas contre :
- Une coupure de courant qui détruit le disque dur (Disponibilité).
- L'erreur de l'admin qui supprime la base élèves (Intégrité).
- L'employé qui poste la liste des salaires sur Facebook (Confidentialité).
- L'ingénierie sociale qui trompe Mariam pour voler son code Momo (Confidentialité + Intégrité du compte).
- Une faille zero-day non encore corrigée (tous piliers).

La sécurité est un processus global (gouvernance, risque, conformité GRC), pas un produit qu'on achète.

LE SAVAIS-TU ? ISO 27001 : la référence mondiale

La norme internationale ISO/CEI 27001 (adoptée par l'ANOR au Cameroun comme norme nationale) définit les exigences pour un **Système de Management de la Sécurité de l'Information (SMSI)**. Son annexe A liste 93 contrôles (version 2022) regroupés en 4 thèmes : Or-

ganisationnels, Personnes, Physiques, Technologiques. Le triptyque C-I-D en est le cœur théorique. Toute entreprise sérieuse (banques, télécoms, administrations) vise cette certification pour prouver sa maturité sécurité.

1.8 Méthode : Vérifier l'intégrité d'un fichier téléchargé (empreinte SHA-256)

MÉTHODE Contrôle d'intégrité par empreinte cryptographique

Pour s'assurer qu'un programme d'installation (ex. `geogebra-linux-x64.tar.gz`) ou une image ISO (ex. `ubuntu-22.04.iso`) n'a pas été corrompu ou remplacé par une version piégée (atteinte à l'intégrité) :

1. Sur le site officiel, repérer l'empreinte SHA-256 publiée (suite de 64 caractères hexadécimaux).
2. Télécharger le fichier.
3. Calculer l'empreinte locale du fichier téléchargé.
4. Comparer caractère par caractère les deux empreintes. Si elles sont identiques → Intégrité OK. Si différent → Fichier corrompu ou modifié → Ne pas exécuter, re-télécharger.

```
# --- SOUS LINUX / MACOS (Terminal) ---
$ sha256sum ubuntu-22.04.3-desktop-amd64.iso
# Résultat attendu (exemple) :
# a1b2c3d4e5f6... ubuntu-22.04.3-desktop-amd64.iso
# Comparer avec la valeur sur le site : https://releases.ubuntu.com/jammy/SHA256SUMS

# --- SOUS WINDOWS (PowerShell) ---
PS C:\Users\Eleve\Downloads> Get-FileHash -Algorithm SHA256 .\ubuntu-22.04.3-desktop-amd64.iso
```

Algorithm	Hash	Path
SHA256	A1B2C3D4E5F67890ABCDEF1234567890ABCDEF1234567890ABCDEF1234567890	C:\Users\Eleve\Downloads\ubuntu-22.04.3-desktop-amd64.iso

```
# --- AUTOMATISATION (Script Bash) ---
#!/bin/bash
FICHIER="geogebra-linux-x64.tar.gz"
EMPREINTE_OFFICIELLE="d4f3e2c1b0a9... (64 chars)"
CALCULEE=$(sha256sum "$FICHIER" | awk '{print $1}')
if [ "$CALCULEE" = "$EMPREINTE_OFFICIELLE" ]; then
    echo "[OK] Intégrité vérifiée : $FICHIER"
else
    echo "[ALERTE] INTÉGRITÉ COMPROMISE ! Ne pas installer."
    exit 1
fi
```

EXERCICE RÉSOLU 1 Analyse d'incidents : identifier le pilier compromis

Énoncé : Pour chacun des scénarios suivants, identifiez le(s) pilier(s) du triptyque C-I-D principalement compromis et justifiez en une phrase.

1. Un élève de 1ère C devine le mot de passe du professeur principal (date de naissance) et consulte les moyennes de la classe avant le conseil de classe.
2. Un virus rançongiciel chiffre tous les fichiers Word/Excel du secrétariat du lycée. La rançon est de 500 000 FCFA en Bitcoin.
3. Lors de la saisie des notes, le professeur tape « 18 » au lieu de « 8 » pour un élève. Le bulletin sort avec la mention « Très Bien » imméritée.
4. Une forte pluie inonde la salle des serveurs du lycée. Les serveurs sont hors service pendant 3 jours. Pas de sauvegarde externe récente.

SOLUTION

Solution détaillée :

1. Confidentialité. L'élève accède à une information (moyennes) sans autorisation. L'intégrité n'est pas touchée (il n'a pas modifié), la disponibilité non plus.
2. Disponibilité (principal) + Intégrité (secondaire). Les fichiers existent mais sont illisibles (indisponibles). Le chiffrement non autorisé est aussi une modification (atteinte à l'intégrité), mais l'impact métier immédiat est l'indisponibilité du service secrétariat.
3. Intégrité. La donnée stockée (18) ne reflète pas la réalité (8). C'est une modification non autorisée (erreur humaine non contrôlée). La confidentialité et la disponibilité sont intactes.
4. Disponibilité. Le service est inaccessible cause physique (inondation). Perte de données possible si pas de sauvegarde → Intégrité aussi compromise si données perdues définitivement.

EXERCICE 1 Auto-évaluation : Le triptyque en situation

Contexte : La bibliothèque numérique du Lycée de Bafoussam gère les emprunts d'ebooks.

1. Un élève modifie la date de retour dans la base de données pour éviter une pénalité de retard.
2. Le serveur de la bibliothèque tombe en panne disque dur le jour du rendu des devoirs de vacances. Aucun RAID, aucune sauvegarde.
3. Un parent d'élève accède à la liste de tous les emprunts de tous les élèves (titres,

dates) via une faille dans l'API non authentifiée.

Questions : Pour chaque situation, citez le pilier principal violé (C, I ou D) et proposez une mesure technique ou organisationnelle concrète pour prévenir cet incident.

CORRIGÉ Exercice n°1 : Auto-évaluation

1. Pilier : Intégrité (I). Modification non autorisée de la date de retour. Protection : Contrôle d'accès basé sur les rôles (RBAC) : l'élève a droit en lecture seule sur ses emprunts, seul le bibliothécaire a droit d'écriture sur les dates. Journal d'audit (log) horodaté et signé de toute modification.
2. Pilier : Disponibilité (D). Service inaccessible cause panne matérielle sans redondance. Protection : Serveur avec disques en RAID 1 (miroir) ou RAID 5/6 + Sauvegarde quotidienne externalisée (règle 3-2-1 : 3 copies, 2 supports différents, 1 hors site). Plan de reprise d'activité (PRA) testé.
3. Pilier : Confidentialité (C). Divulgaration de données personnelles (historique de lecture) à un tiers non autorisé. Protection : Authentification forte obligatoire sur l'API (JWT/OAuth2, API Key), chiffrement TLS 1.3 pour le transport, principe du moindre privilège (l'API ne renvoie que les emprunts de l'utilisateur connecté), tests de pénétration (pentest) annuels.

2 CYBERCRIMINALITÉ ET CYBERSÉCURITÉ

Dans la section précédente, nous avons posé les fondations de la sécurité informatique à travers le triptyque **Confidentialité – Intégrité – Disponibilité** (CID). Nous savons désormais quoi protéger. Il nous reste à comprendre contre qui et contre quoi nous protégeons ces actifs. C'est tout l'objet de la distinction entre cybercriminalité (la menace offensive) et cybersécurité (la réponse défensive).

2.1 Définition et portée de la cybercriminalité

DÉFINITION Cybercriminalité

La **cybercriminalité** désigne l'ensemble des infractions pénales commises par le biais des technologies de l'information et de la communication (TIC) ou contre des systèmes d'information. Elle englobe aussi bien les attaques ciblant l'ordinateur comme outil (fraude, diffusion de contenus illicites) que celles le ciblant comme victime (intrusion, destruction de données, rançongiciel).

Concrètement, dès lors qu'un acte réprimé par le code pénal est facilité par un ordinateur, un smartphone ou un réseau (Internet, réseau local d'entreprise), on bascule dans la cybercriminalité. Le **cybercriminel** (souvent appelé pirate informatique ou black hat dans le jargon technique) agit sous couvert d'anonymat, souvent depuis un autre pays, ce qui complique les enquêtes.

ATTENTION Hacker ≠ Cybercriminel

Ne confonds pas hacker et cybercriminel. Un **hacker** est avant tout un expert technique capable de comprendre, modifier ou contourner le fonctionnement d'un système. Il existe des white hats (hackers éthiques, payés pour tester la sécurité) et des grey hats. Le cybercriminel (ou black hat) utilise ses compétences à des fins illégales : vol, chantage, espionnage, nuisance. Dans le langage courant, on dit souvent « pirate » pour désigner le cybercriminel.

EXEMPLE Arnaque aux faux sites e-commerce au Cameroun (2020)

En période de confinement (Covid-19), de nombreux Camerounais ont commandé du matériel (téléphones, ordinateurs) sur des pages Facebook imitant des boutiques réputées (ex. « Jumia Cameroun Officiel » avec un léger changement d'orthographe). Après paiement via Mobile Money (MTN MoMo / Orange Money), les vendeurs disparaissaient. Il s'agit d'une cybercriminalité classique : escroquerie par usurpation d'identité numérique (faux site, faux profil) et vol de données bancaires.

LE SAVAIS-TU ? L'ANTIC, garde-fou national

Le Cameroun dispose d'une structure étatique dédiée : l'ANTIC (Agence Nationale des Technologies de l'Information et de la Communication), créée par le décret n°2002/001 et renforcée par la loi de 2010. L'ANTIC gère le **CERT-CM** (Computer Emergency Response Team), qui reçoit les signalements d'incidents, alerte sur les failles critiques et accompagne les administrations et entreprises dans la sécurisation de leurs SI. Tu peux signaler une attaque sur www.antic.cm ou par SMS au 8202.

2.2 La cybersécurité : la réponse défensive

DÉFINITION Cybersécurité

La **cybersécurité** (ou sécurité du cyberspace) est l'ensemble des mesures techniques, politiques organisationnelles, procédures juridiques et bonnes pratiques destinées à

protéger les personnes, les réseaux, les systèmes d'information et les données contre les cyberattaques, afin de garantir la confidentialité, l'intégrité et la disponibilité (triptyque CID).

La distinction est nette : la **cybercriminalité est l'attaque (l'offensive)**, la **cybersécurité est la défense**. C'est une course permanente : à chaque nouvelle technique d'attaque (exploit zero-day, nouveau rançongiciel), la cybersécurité répond par un correctif, une règle de pare-feu, une campagne de sensibilisation.

PROPRIÉTÉ Victimes potentielles – Personne n'est à l'abri

La cybercriminalité ne vise pas seulement les grandes banques. Les cibles sont :

- Particuliers : vol d'identité, arnaque au sentiment (romance scam), rançongiciel sur photos personnelles.
- Entreprises (PME/PMI) : espionnage industriel, vol de base clients, paralysie d'activité (rançongiciel).
- Banques / Mobile Money : fraude à la carte, blanchiment, attaque sur les API de paiement.
- Administrations / Écoles : fuite de notes, de dossiers médicaux, paralysie des services en ligne (ex. portail www.minesec.gov.cm).

2.3 Cadre légal au Cameroun : la loi n°2010/012

À RETENIR Loi n°2010/012 du 21 décembre 2010 – Point clé pour le Probatoire

Le Cameroun s'est doté d'un arsenal juridique spécifique : la loi n°2010/012 relative à la cybersécurité et à la cybercriminalité. Elle définit les infractions, les peines et les pouvoirs d'enquête.

- Accès frauduleux / maintien dans un SI (art. 5) : 6 mois à 5 ans de prison + amende.
- Entrave au fonctionnement d'un SI (art. 6 – déni de service, virus) : 1 à 5 ans de prison.
- Interception illicite de données (art. 7) : 1 à 5 ans.
- Usurpation d'identité / faux numérique (art. 10) : 2 à 10 ans.
- Escroquerie informatique (art. 11) : 2 à 10 ans.
- Pédopornographie / apologie du terrorisme (art. 13-14) : peines maximales (10-20 ans).

La loi prévoit aussi la responsabilité des fournisseurs d'accès (CAMTEL, MTN, Orange, Viettel) qui doivent conserver les données de connexion (logs) pendant 1 an et collaborer

avec la justice.

EXERCICE RÉSOLU 2 Analyse d'un scénario d'arnaque Mobile Money

Énoncé : Paul reçoit un SMS : « ALERTE : Votre compte MoMo sera fermé dans 2h. Validez votre identité ici : <http://momo-cm-validation.xyz> ». Il clique, entre son numéro et son code PIN. Deux minutes plus tard, son solde est à 0 FCFA.

Questions :

1. Qualifie l'infraction au regard de la loi 2010/012.
2. Identifie la technique d'attaque utilisée.
3. Cite deux mesures de cybersécurité qui auraient pu protéger Paul.

SOLUTION

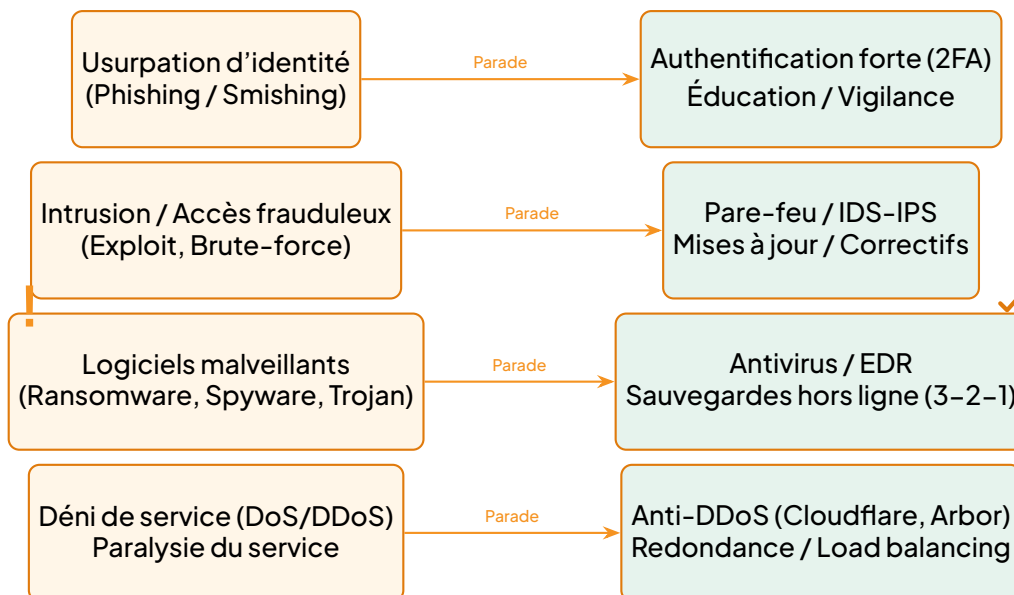
Solution détaillée :

1. Infraction : Accès frauduleux à un système de traitement automatisé de données (art. 5) + Escroquerie informatique (art. 11). L'auteur a utilisé un faux site (usurpation d'identité de MTN) pour obtenir le code PIN (donnée confidentielle) et détourner l'argent.
2. Technique : **Hameçonnage (phishing)** par SMS (**smishing**). L'URL `.xyz` bon marché, l'urgence (2h), la demande de code PIN (jamais demandé par l'opérateur) sont les indices.
3. Protection :
 - Sensibilisation (facteur humain) : Ne jamais communiquer son code PIN/OTP ; vérifier l'URL officielle (`mtn.cm`, `orange.cm`) ; contacter le service client (*123# ou 8080) en cas de doute.
 - Double authentification (2FA) / Code OTP : Même avec le PIN, l'attaquant aurait besoin du code OTP envoyé par SMS sur le téléphone de Paul (sauf si la carte SIM est clonée – SIM swap, attaque plus sophistiquée).

2.4 Illustrations synthétiques

Cybercriminalité (Attaque) Cybersécurité (Défense)

► Menaces ► Vulnérabilités ► Exploits
► Protection ► Détection ► Réponse



Opposition systématique : à chaque type d'attaque (colonne gauche) correspond une ou plusieurs mesures de défense (colonne droite). La cybersécurité n'est pas un produit unique, mais un processus continu en couches (defense in depth).



Chaîne de l'incident de sécurité : de la victime à la réponse. La cybersécurité agit en amont (protection) et en aval (détection, réponse, légal).

MÉTHODE Réagir face à une cyberattaque (réflexes de base)

Si tu es victime ou témoin :

1. Ne paie jamais de rançon (rançongiciel) : rien ne garantit la récupération des données et cela finance le crime.
2. Déconnecte le poste du réseau (câble / Wi-Fi) pour limiter la propagation.

3. Préserve les preuves : captures d'écran (SMS, email, URL), fichiers logs, horodatage. Ne réinstalle pas l'OS avant expertise.
4. Change tes mots de passe depuis un appareil sain (gestionnaire de mots de passe recommandé).
5. Signale : www.antic.cm (CERT-CM), commissariat / gendarmerie (plainte), opérateur Mobile Money (blocage rapide).
6. Restaure à partir d'une sauvegarde saine (règle 3-2-1 : 3 copies, 2 supports différents, 1 hors site).

EXERCICE 2 Entraînement – Qualification juridique

Pour chaque situation, cite l'article probable de la loi 2010/012 et la peine encourue (fourchette).

1. Un élève installe un keylogger sur le PC du prof pour récupérer le mot de passe de la base notes.
2. Un groupe lance une attaque DDoS sur le site de la BEPC pendant la publication des résultats.
3. Un agent de banque copie la base clients et la vend à une assurance.
4. Quelqu'un crée un faux profil Facebook au nom du Proviseur pour demander de l'argent aux parents.

CORRIGÉ Exercice n°1 – Qualification juridique

1. Art. 5 (Accès frauduleux) + Art. 7 (Interception). Peine : 1 à 5 ans prison + amende.
2. Art. 6 (Entrave au fonctionnement). Peine : 1 à 5 ans prison + amende (circonstance aggravante : service public).
3. Art. 7 (Interception) + Art. 11 (Escroquerie/Abus de confiance). Peine : 2 à 10 ans.
4. Art. 10 (Usurpation d'identité numérique) + Art. 11 (Escroquerie). Peine : 2 à 10 ans.

3 QUELQUES ACTES DE CYBERCRIMINALITÉ

Dans la section précédente, nous avons défini la cybercriminalité comme l'ensemble des infractions pénales commises au moyen d'un système informatique ou d'un réseau, et la cyber-

sécurité comme l'ensemble des moyens mis en œuvre pour s'en protéger. Mais de quoi ont réellement l'air ces infractions dans la vie quotidienne ? Un élève de Première qui reçoit un SMS annonçant que son compte Mobile Money sera « bloqué sous 24 heures » s'il ne confirme pas son code secret, un proviseur dont la photo est utilisée pour créer un faux profil Facebook, le site d'un établissement scolaire rendu inaccessible la veille de la publication des résultats : ce sont là des **actes de cybercriminalité** bien concrets. Cette section les décrit un à un, en montrant pour chacun le mécanisme, un exemple camerounais réaliste, et le pilier de la sécurité (Confidentialité, Intégrité, Disponibilité) qu'il menace.

3.1 Vol d'identité

DÉFINITION Vol d'identité

Le **vol d'identité** est l'utilisation frauduleuse des informations personnelles d'une personne (nom, prénom, date de naissance, photographie, numéro de carte nationale d'identité, numéro de téléphone) pour se faire passer pour elle et agir en son nom, généralement à des fins d'escroquerie ou de diffamation.

L'attaquant n'a pas besoin de « pirater » quoi que ce soit : il lui suffit souvent de recopier les informations publiques d'un profil Facebook ou WhatsApp (photo, nom, établissement) pour créer un compte jumeau. Il contacte ensuite les amis de la victime en se faisant passer pour elle, par exemple pour demander un transfert d'argent « urgent ». Le pilier menacé est la **confidentialité** (des données personnelles sont détournées) et, indirectement, l'**intégrité** de l'identité numérique de la victime.

ATTENTION Erreur fréquente

Croire que seuls les ordinateurs sont visés par la cybercriminalité est une erreur grave. Au Cameroun, le téléphone mobile est aujourd'hui la cible principale : SMS frauduleux, faux comptes WhatsApp, arnaques au Mobile Money (MoMo) et à Orange Money. Toute information publiée sur ton téléphone (photo de profil, statut, numéro) peut servir à un vol d'identité. Règle d'or : limite la visibilité de tes informations personnelles dans les paramètres de confidentialité.

3.2 Vol et craquage de mot de passe

Le mot de passe est la clé de nos comptes. Deux actes distincts visent à s'en emparer : le vol et le craquage.

DÉFINITION Vol de mot de passe

Le **vol de mot de passe** consiste à obtenir frauduleusement les identifiants (nom d'utilisateur et mot de passe) d'un compte, par exemple par observation (regarder par-dessus

l'épaule au cybercafé), par un logiciel espion (keylogger) qui enregistre les touches frappées, ou par un faux site imitant la page de connexion officielle.

DÉFINITION Craquage de mot de passe

Le **craquage de mot de passe** est la recherche systématique du mot de passe d'un compte par essais successifs automatisés. On distingue :

- l'attaque par force brute : on teste toutes les combinaisons possibles (aaaa, aaab, ...);
- l'attaque par dictionnaire : on teste une liste de mots de passe fréquents (123456, password, prénoms, dates de naissance).

EXEMPLE Exemple chiffré : pourquoi la longueur du mot de passe compte

Supposons qu'un programme de craquage teste 1000 mots de passe par seconde.

- Mot de passe de 4 chiffres : il existe $10^4 = 10000$ combinaisons. Temps maximal :

$$\frac{10000}{1000} = 10 \text{ secondes}$$

- Mot de passe de 8 caractères choisis parmi 62 symboles (26 minuscules + 26 majuscules + 10 chiffres) : il existe $62^8 \approx 2,18 \times 10^{14}$ combinaisons, soit un temps maximal de

$$\frac{2,18 \times 10^{14}}{1000} \approx 2,18 \times 10^{11} \text{ s} \approx 6900 \text{ ans.}$$

Conclusion : chaque caractère supplémentaire multiplie le temps de craquage par le nombre de symboles possibles. Un mot de passe long et varié rend la force brute pratiquement inutilisable.

Le vol et le craquage de mot de passe menacent directement la **confidentialité** : l'attaquant accède à des données et à des comptes qui ne lui appartiennent pas.

3.3 Intrusion non autorisée

DÉFINITION Intrusion non autorisée

L'**intrusion non autorisée** est la pénétration illégale dans un système informatique, un réseau ou un compte, sans l'autorisation de son propriétaire ou de son administrateur, que l'intrus ait ou non causé des dommages.

L'intrus exploite une faille : mot de passe trop faible, logiciel non mis à jour, port réseau laissé ouvert. Une fois à l'intérieur, il peut lire des fichiers (atteinte à la **confidentialité**), modifier ou supprimer des données (atteinte à l'**intégrité**) ou bloquer le système (atteinte à la **disponibilité**). Exemple : un individu s'introduit dans le réseau Wi-Fi d'une bibliothèque scolaire dont le mot de passe est resté « 12345678 » et consulte les bulletins de notes stockés sur le serveur.

3.4 Publication de faux documents

DÉFINITION Publication de faux documents

La **publication de faux documents** consiste à créer et à diffuser des documents falsifiés — faux diplômes, fausses annonces officielles, faux communiqués, montages photo ou vidéo — pour tromper le public, nuire à une personne ou obtenir un avantage indu.

Les logiciels de retouche d'image et les réseaux sociaux rendent ce délit facile : une fausse « décision » attribuée à un ministère peut être partagée des milliers de fois avant d'être démentie. Le pilier menacé est l'**intégrité** : on ne peut plus faire confiance à l'authenticité de l'information. Réflexe à adopter : toujours vérifier une annonce sur le site officiel de l'organisme (par exemple celui du MINESEC pour les examens) avant de la croire ou de la partager.

3.5 Déni de service (DoS)

DÉFINITION Déni de service

Le **déni de service** (en anglais Denial of Service, DoS) est une attaque qui consiste à saturer un serveur ou un réseau par un flot massif de requêtes, afin d'épuiser ses ressources (mémoire, processeur, bande passante) et de le rendre indisponible pour les utilisateurs légitimes. Lorsque l'attaque provient de nombreuses machines simultanément, on parle de déni de service distribué (DDoS).

Imagine un cybercafé où mille personnes entreraient en même temps pour poser chacune une question inutile : les employés, débordés, ne pourraient plus servir les vrais clients. C'est exactement le principe du DoS. Le pilier visé est la **disponibilité** : le service existe toujours, mais personne ne peut plus l'utiliser. Exemple : le site de publication des résultats d'un examen devient inaccessible parce qu'il est bombardé de millions de requêtes par seconde.

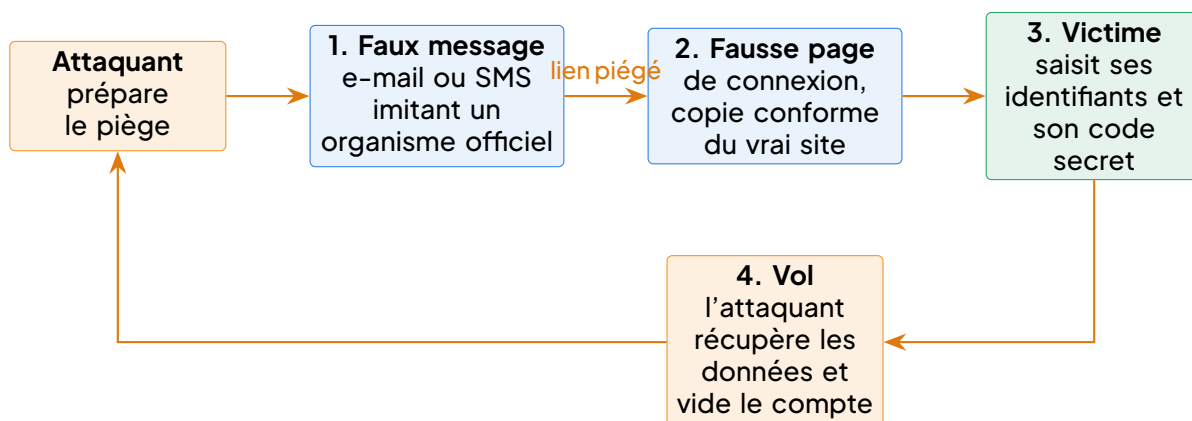
3.6 Hameçonnage (phishing)

DÉFINITION Hameçonnage

L'**hameçonnage** (en anglais phishing) est une technique frauduleuse consistant à envoyer des messages (e-mails, SMS) ou à créer des sites web imitant un organisme de confiance

(banque, opérateur téléphonique, administration) afin de soutirer à la victime des données personnelles et confidentielles : identifiants, mots de passe, codes secrets, numéros de carte bancaire.

Le mécanisme suit toujours le même scénario en quatre étapes, illustré par la figure ci-dessous.



Mécanisme d'une attaque par hameçonnage : du faux message au vol des identifiants.

MÉTHODE Repérer et bloquer un hameçonnage

1. Vérifier l'adresse exacte de l'expéditeur : un vrai message de ta banque ne vient jamais d'une adresse comme `banque.secure-verif@mail-gratuit.com`. Regarde le domaine après le @.
2. Se méfier de l'urgence et des menaces : « votre compte sera bloqué sous 24 h » est un procédé classique pour te faire paniquer et agir sans réfléchir.
3. Repérer les fautes d'orthographe et les formulations étranges, fréquentes dans les messages frauduleux.
4. Ne jamais cliquer sur un lien suspect : taper soi-même l'adresse officielle du site dans le navigateur.
5. Ne jamais communiquer un code secret (code PIN, code de validation reçu par SMS) : aucun organisme sérieux ne le demande par message ou par téléphone.
6. En cas de doute, appeler l'organisme par son numéro officiel pour vérifier.

LESAVAIS-TU ? D'où vient le mot « phishing » ?

Le terme phishing vient de l'anglais fishing, qui signifie « pêche ». Le criminel est un pêcheur : il jette un appât (le faux message) à des milliers de personnes et attend que quelques-unes « mordent » en cliquant. Le « ph » est un clin d'œil à l'ancien phreaking, le piratage des réseaux téléphoniques des années 1970. Au Cameroun, la « pêche » se fait aujourd'hui surtout par SMS et WhatsApp, avec des appâts comme de faux concours, de faux gains ou de fausses alertes Mobile Money.

3.7 Ingénierie sociale

DÉFINITION Ingénierie sociale

L'**ingénierie sociale** est la manipulation psychologique des personnes — plutôt que l'attaque technique des machines — pour les amener à révéler elles-mêmes des informations confidentielles ou à accomplir une action dangereuse (ouvrir une pièce jointe, effectuer un transfert, donner un code).

L'ingénierie sociale exploite la confiance, la politesse, la peur ou l'autorité. Exemple typique : un faux appel du « service client » de ton opérateur, très aimable et très professionnel, qui t'annonce un « problème de sécurité » sur ton compte et te demande de lui lire le code que tu viens de recevoir par SMS. Ce code est précisément celui qui permet de vider ton compte : en le dictant, tu ouvres toi-même la porte. L'hameçonnage est d'ailleurs une forme d'ingénierie sociale automatisée par message.

EXERCICE RÉSOLU 3 Analyser un message suspect

Un élève reçoit le SMS suivant : « FELICITATION! Votre numero a ete tire au sort PROMO-BACK-TO-SCHOOL. Vous gagnez 50 000 F. Envoyez votre code MoMo au 6XX XX XX XX pour recevoir votre gain avant ce soir 18h. » Identifier les indices de fraude, nommer les actes de cybercriminalité mis en jeu et le pilier menacé, puis proposer la bonne réaction.

SOLUTION

Indices de fraude : (1) fautes et orthographe approximative (« FELICITATION », accents absents); (2) gain à un tirage auquel l'élève ne s'est jamais inscrit; (3) sentiment d'urgence artificiel (« avant ce soir 18h »); (4) demande d'un code secret, ce qu'aucun opérateur ne fait jamais; (5) numéro d'expéditeur ordinaire et non un canal officiel.

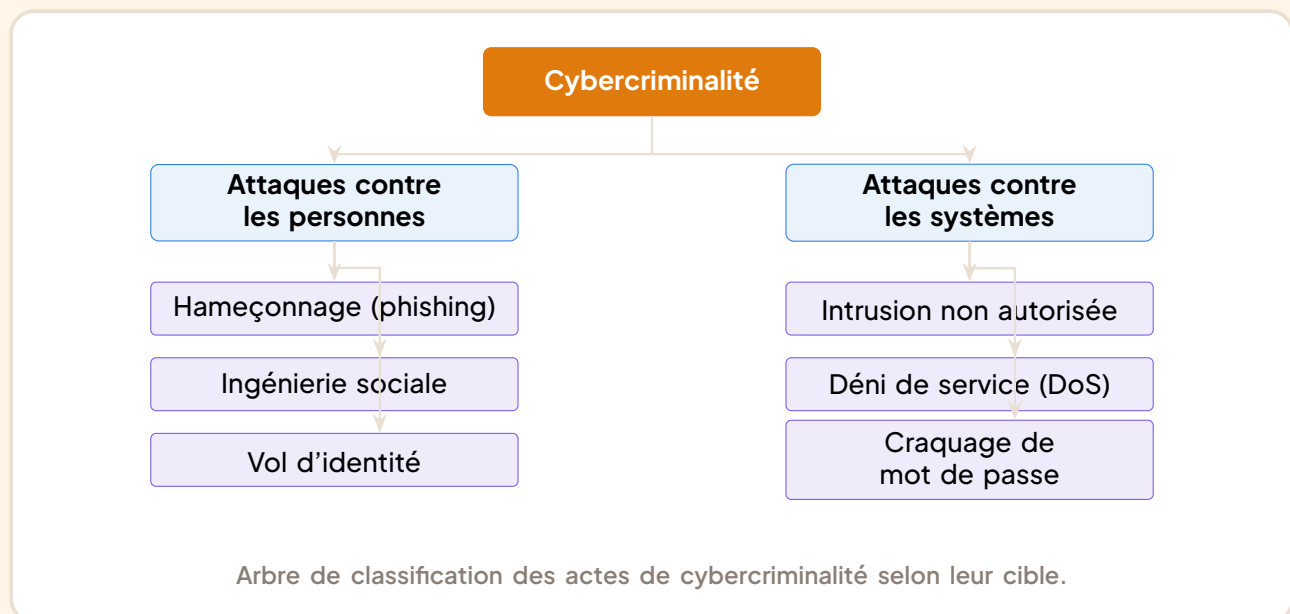
Actes mis en jeu : il s'agit d'un hameçonnage par SMS (parfois appelé smishing), reposant sur l'ingénierie sociale (manipulation par l'appât du gain), et visant le vol du code secret du compte Mobile Money.

Pilier menacé : la confidentialité (le code secret et l'argent du compte).

Bonne réaction : ne pas répondre, ne transmettre aucun code, supprimer le message, signaler le numéro à l'opérateur, et en parler à un adulte ou à l'enseignant. On peut vérifier l'existence réelle d'une promotion uniquement via les canaux officiels de l'opérateur.

3.8 Classification des attaques et lien avec les piliers C-I-D

On peut classer ces actes en deux grandes familles selon leur cible : la personne ou le système.



Le tableau suivant synthétise les huit actes étudiés et le pilier de la sécurité — Confidentialité (C), Intégrité (I), Disponibilité (D) — que chacun menace en priorité.

Acte	Description courte	Pilier	Exemple concret
Vol d'identité	Utilisation frauduleuse des informations personnelles d'autrui	C	Faux compte Facebook au nom d'un élève, avec ses photos
Vol de mot de passe	Obtention frauduleuse des identifiants d'un compte	C	Logiciel espion sur un poste de cybercafé
Intrusion non autorisée	Pénétration illégale dans un système ou un réseau	C (I, D)	Accès illégal au serveur des notes d'un lycée
Publication de faux documents	Création et diffusion de documents falsifiés	I	Fausse annonce de report d'examen attribuée au MINESEC
Craquage de mot de passe	Recherche systématique par force brute ou dictionnaire	C	Programme testant des milliers de mots de passe par seconde
Déni de service (DoS)	Saturation d'un serveur par un flot de requêtes	D	Site de résultats inaccessible le jour de la proclamation
Hameçonnage (phishing)	Messages frauduleux imitant un organisme officiel	C	Faux SMS « banque » demandant de confirmer ses identifiants
Ingénierie sociale	Manipulation psychologique de la victime	C	Faux appel du « service client » demandant un code secret

À RETENIR L'essentiel

- Chaque acte de cybercriminalité vise un ou plusieurs piliers : confidentialité (vol, hameçonnage, craquage, intrusion), intégrité (faux documents, modification de données), disponibilité (déni de service).
- Les attaques contre les personnes (phishing, ingénierie sociale, vol d'identité) exploitent la confiance et l'inattention ; celles contre les systèmes (intrusion, DoS, craquage) exploitent les failles techniques.
- Le maillon le plus faible de la sécurité est souvent l'utilisateur : la vigilance (vérifier l'expéditeur, refuser l'urgence, ne jamais donner un code secret) est la première des protections.

Maintenant que nous savons reconnaître ces attaques, la section suivante présentera les techniques concrètes de protection des données et des logiciels : antivirus, pare-feu et bonnes pratiques de mots de passe.

4 TECHNIQUES DE PROTECTION DES DONNÉES ET DES LOGICIELS

Dans la section précédente, nous avons dressé un inventaire des principaux actes de cybercriminalité : vol d'identité, hameçonnage, intrusion non autorisée, déni de service, ingénierie sociale... Face à cette liste, une question se pose naturellement : comment se défendre ? Imagine le lycée de ta ville : pour protéger les élèves et les archives, on installe un portail avec un gardien (qui filtre les entrées), on donne à chaque enseignant une clé personnelle (qui authentifie), on vaccine les élèves contre les épidémies (qui neutralise les menaces internes), et on fait des photocopies des registres conservées ailleurs (qui permet de rebondir après un sinistre). La sécurité informatique repose exactement sur la même logique, avec des outils numériques : le **pare-feu**, le **mot de passe**, l'**antivirus** et les **bonnes pratiques**. C'est ce que nous allons étudier maintenant, en montrant à chaque fois quel pilier (confidentialité, intégrité, disponibilité) chaque technique protège.

4.1 L'antivirus : le médecin du système

Intuition. Un virus informatique, comme un virus biologique, s'introduit discrètement dans l'organisme (ici, ton ordinateur), s'y reproduit et y cause des dégâts : fichiers effacés, données espionnées, machine ralentie. Or, à l'ère des clés USB qui circulent entre les salles multimédias et les cybercafés de Yaoundé ou de Douala, aucun poste n'est à l'abri. Il faut donc un « médecin » capable de reconnaître l'intrus, de l'isoler et de l'éliminer.

DÉFINITION Antivirus

Un **antivirus** est un logiciel chargé de détecter, neutraliser et supprimer les programmes malveillants (virus, vers, chevaux de Troie, logiciels espions) présents dans un système informatique, et d'en bloquer l'entrée.

Fonctionnement. Un antivirus travaille selon deux mécanismes complémentaires :

- **l'analyse par signatures** : il compare chaque fichier à une base de signatures, c'est-à-dire une liste d'« empreintes » de logiciels malveillants connus. C'est le contrôle d'identité au commissariat : si le fichier figure au fichier des recherchés, il est arrêté ;
- **l'analyse comportementale (heuristique)** : il surveille les actions suspectes (un programme qui tente de modifier des fichiers système, de se copier sur tous les supports amovibles...) et bloque même des menaces encore inconnues.

PROPRIÉTÉ Nécessité des mises à jour

Un antivirus n'est efficace que si sa base de signatures est régulièrement mise à jour. Des milliers de nouveaux logiciels malveillants apparaissent chaque jour : un antivirus non mis à jour depuis six mois est comme un gardien avec une liste de voleurs périmée — il laisse passer les nouveaux criminels sans les reconnaître.

EXEMPLE Antivirus courants

- Windows Defender (intégré à Windows, activé par défaut) ;
- Avast, Kaspersky, Bitdefender, Avira (solutions tierces, gratuites ou payantes).

Dans la salle informatique du lycée, l'administrateur programme généralement une analyse complète hebdomadaire et active la mise à jour automatique.

ATTENTION Un seul antivirus à la fois

Installer deux antivirus sur le même poste est une erreur classique : ils se neutralisent mutuellement (chacun prend l'autre pour un programme suspect) et ralentissent fortement la machine. Un seul antivirus, mais à jour et actif en permanence.

4.2 Le pare-feu : la muraille filtrante

Intuition. Ton ordinateur connecté à Internet échange en permanence des données avec l'extérieur. Mais tout ce qui vient d'Internet n'est pas désirable : des pirates scannent en continu les machines connectées à la recherche d'une porte ouverte. Le pare-feu joue le rôle du portail gardé du lycée : il examine chaque « visiteur » (paquet de données) et décide, selon des règles précises, de le laisser entrer ou de le refouler.

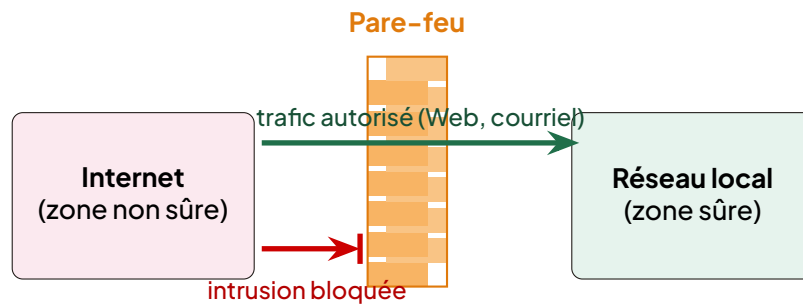
DÉFINITION Pare-feu

Un **pare-feu** (en anglais firewall) est un dispositif — logiciel ou matériel — qui contrôle et filtre le trafic entrant et sortant d'un réseau ou d'un ordinateur, selon des règles de sécurité définies par l'administrateur. Il bloque les accès non autorisés tout en laissant passer les communications légitimes.

Sur quels critères filtre-t-il ? Une règle de pare-feu examine typiquement :

- l'**adresse IP** source et destination (d'où vient le paquet, où va-t-il) ;
- le **port** utilisé (par exemple le port 80 pour le Web, le port 25 pour le courriel) ;
- le **protocole** (TCP, UDP...) ;
- le **sens** de la communication (entrant ou sortant).

Exemple de règle rédigée en langage naturel : « Autoriser le trafic entrant vers le port 80 du serveur Web du lycée ; bloquer tout le reste du trafic entrant provenant d'Internet. »



Le pare-feu filtre les échanges entre Internet (zone non sûre) et le réseau local (zone sûre) : le trafic légitime passe, les intrusions sont bloquées.

EXEMPLE Pare-feu logiciel et pare-feu matériel

- Logiciel : le pare-feu intégré à Windows (Pare-feu Windows Defender) protège un poste individuel ; on peut y autoriser ou interdire des applications précises.
- Matériel : dans les grands réseaux (ministères, universités, CAMTEL), un boîtier dédié est placé entre le réseau interne et la liaison Internet et filtre tout le trafic de l'organisation.

4.3 Le mot de passe : la clé de l'authentification

Intuition. Le pare-feu protège le réseau, l'antivirus protège la machine... mais comment l'ordinateur sait-il que c'est bien toi qui te connectes à ta session, à ta boîte mail ou à ta plateforme de notes en ligne ? Grâce à un secret que toi seul connais : le mot de passe. C'est la clé de ta maison numérique.

DÉFINITION Mot de passe

Un **mot de passe** est une suite de caractères secrète, associée à un identifiant, qui permet d'authentifier un utilisateur, c'est-à-dire de vérifier son identité avant de lui donner accès à une ressource.

PROPRIÉTÉ Critères d'un mot de passe robuste

Un mot de passe est dit robuste s'il respecte les conditions suivantes :

1. contenir au moins 8 caractères (idéalement 12 ou plus) ;
2. mélanger majuscules, minuscules, chiffres et symboles (@, !, #...);

3. ne contenir aucune information personnelle (prénom, date de naissance, nom du quartier) facile à deviner ;
4. être différent pour chaque compte : si un compte est piraté, les autres restent protégés.

MÉTHODE Fabriquer un mot de passe robuste et mémorisable

1. Choisir une phrase personnelle facile à retenir, par exemple : « J'aime le ndolé de 2024! ».
2. En extraire les initiales et conserver les chiffres et symboles : J'lnd12024!.
3. Vérifier les critères : 10 caractères, majuscule, minuscules, chiffres, symbole — c'est validé.
4. Décliner la phrase différemment pour chaque compte (une phrase pour la messagerie, une autre pour le réseau social), afin de ne jamais réutiliser le même mot de passe.

Pourquoi la longueur est-elle décisive ? Une attaque par force brute consiste à essayer toutes les combinaisons possibles. Si un mot de passe ne comporte que des chiffres, il y a 10 possibilités par caractère ; avec 4 types de caractères (environ 70 symboles différents), il y en a environ 70 par position. Le nombre de combinaisons explose avec la longueur :

6 chiffres : $10^6 = 1\,000\,000$ combinaisons ; 10 caractères mixtes : $70^{10} \approx 2,8 \times 10^{18}$.

EXEMPLE Exemple chiffré : force brute

Avec un ordinateur testant un milliard (10^9) de mots de passe par seconde :

- 123456 : cassé instantanément (il figure en tête de tous les dictionnaires de mots de passe courants) ;
- yvan2008 : cassé en quelques secondes (prénom + année de naissance : très prévisible) ;
- Y@ounde2024! : environ $70^{12} \approx 1,4 \times 10^{22}$ combinaisons, soit des centaines de milliers d'années d'attaque par force brute — le pirate abandonne bien avant.

ATTENTION L'erreur qui annule tout

Noter son mot de passe sur un papier collé à l'écran, l'enregistrer dans un fichier nommé `motdepasse.txt` sur le bureau, ou le partager avec un ami « de confiance » annule totalement la protection. Le mot de passe le plus robuste du monde ne vaut rien s'il est divulgué.

De même, ne jamais le communiquer par téléphone ou par message, même à quelqu'un qui prétend être un technicien (c'est le principe de l'ingénierie sociale vu à la section précédente).

4.4 Bonnes pratiques complémentaires

Les trois outils précédents sont au programme officiel ; les pratiques suivantes sont un **complément utile pour le Probatoire** et pour ta vie numérique quotidienne.

À RETENIR Les quatre réflexes complémentaires

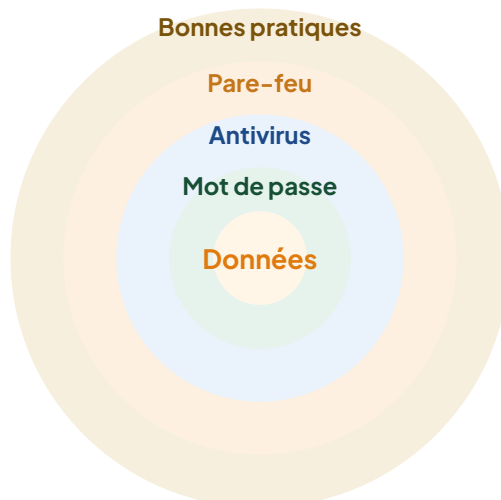
1. Mettre à jour le système d'exploitation et les logiciels : les mises à jour corrigent des failles de sécurité que les pirates exploitent. Un système non mis à jour est une porte restée ouverte.
2. Sauvegarder régulièrement ses données (clé USB, disque externe, espace en ligne) : en cas de panne, de vol ou d'attaque (rançongiciel), on retrouve ses fichiers. La sauvegarde garantit la disponibilité.
3. Être prudent sur les réseaux sociaux : ne pas publier ses informations personnelles (date de naissance, adresse, emploi du temps), qui servent aux usurpateurs d'identité et aux attaques d'ingénierie sociale.
4. Verrouiller sa session dès qu'on quitte le poste (combinaison `Windows + L`) : au cyber-café ou en salle multimédia, un écran laissé ouvert, c'est sa session offerte au premier venu.

4.5 Synthèse : protections, piliers et limites

Chaque technique de protection défend un ou plusieurs piliers de la sécurité informatique étudiés en début de leçon. Le tableau suivant résume cette correspondance — retiens-le, c'est une question classique d'évaluation.

Protection	Rôle principal	Pilier(s) protégé(s)
Mot de passe	Empêche l'accès aux données par un inconnu	Confidentialité
Pare-feu	Bloque les accès réseau non autorisés	Confidentialité
Antivirus	Empêche la modification ou la destruction des fichiers par des logiciels malveillants	Intégrité et disponibilité
Sauvegarde	Permet de restaurer les données après un sinistre	Disponibilité
Mises à jour	Corrige les failles exploitables	Intégrité et disponibilité

Aucune de ces protections ne suffit seule : c'est leur **combinaison en couches successives** qui rend le système difficile à attaquer. On parle de **défense en profondeur** : comme un oignon, les données précieuses sont au centre, entourées de couches de protection que l'attaquant doit franchir une à une.



La défense en profondeur : les données sont protégées par des couches successives. L'attaquant doit franchir chaque couche pour atteindre le centre.

EXERCICE RÉSOLU 4 Associer une protection à une situation

Énoncé. Le secrétariat du Lycée bilingue de Bafoussam subit quatre incidents : (a) un élève ouvre la session du surveillant général laissée sans secret ; (b) un pirate tente de se connecter au réseau du lycée depuis l'extérieur ; (c) une clé USB infectée détruit des fichiers sur le poste de la comptabilité ; (d) le disque dur du serveur de notes tombe en panne. Pour chaque incident, indique la technique de protection qui l'aurait empêché ou limité, et le pilier concerné.

SOLUTION

Solution.

- (a) Un mot de passe de session (et le verrouillage de l'écran) aurait empêché l'accès : pilier confidentialité.
- (b) Un pare-feu correctement configuré bloque la connexion entrante non autorisée : pilier confidentialité.
- (c) Un antivirus à jour aurait détecté et neutralisé le logiciel malveillant de la clé USB avant la destruction des fichiers : piliers intégrité et disponibilité.
- (d) Des sauvegardes régulières des notes sur un support externe auraient permis de restaurer les données après la panne : pilier disponibilité.

EXPÉRIENCE**TP guidé : vérifier les protections d'un poste Windows**

Objectif : vérifier que le poste de la salle informatique est correctement protégé.

Matériel : un ordinateur sous Windows 10/11 connecté à Internet.

Manipulation :

1. Ouvrir Paramètres → Mise à jour et sécurité → Sécurité Windows. Noter si l'antivirus (Windows Defender) est actif et si sa base de signatures est à jour.
2. Dans le même menu, ouvrir Pare-feu et protection réseau et vérifier que le pare-feu est activé pour les réseaux privé et public.
3. Ouvrir Comptes → Options de connexion et constater qu'un mot de passe de session est exigé.
4. Tester le verrouillage : appuyer sur Windows + L, puis se reconnecter avec le mot de passe.

Observations et interprétation : si l'un des trois voyants (antivirus, pare-feu, mot de passe) est au rouge, le poste présente une faille exploitable. Conclure en rédigeant un petit rapport indiquant, pour chaque protection vérifiée, le pilier de sécurité qu'elle garantit.

LE SAVAIS-TU ?**Le maillon faible, c'est souvent l'humain**

Les études des spécialistes en cybersécurité convergent : la majorité des piratages réussissent non pas à cause d'une faille technique, mais à cause d'un mot de passe faible, divulgué ou réutilisé, ou d'un utilisateur trompé par un message frauduleux. C'est pourquoi les experts répètent : « la vigilance de l'utilisateur est la première barrière de la sécurité ». Au Cameroun, la loi n° 2010/012 du 21 décembre 2010 relative à la cybersécurité et à la cyber-

criminalité sanctionne d'ailleurs sévèrement les intrusions et les vols de données — mais la meilleure des lois ne remplace pas un bon mot de passe !

À RETENIR L'essentiel de la section

- L'antivirus détecte, neutralise et supprime les logiciels malveillants ; il doit être mis à jour régulièrement.
- Le pare-feu filtre le trafic entrant et sortant selon des règles de sécurité et bloque les accès non autorisés.
- Le mot de passe authentifie l'utilisateur ; il est robuste s'il compte au moins 8 caractères mêlant majuscules, minuscules, chiffres et symboles, sans information personnelle, et s'il est unique par compte.
- Les bonnes pratiques (mises à jour, sauvegardes, prudence sur les réseaux sociaux, verrouillage de session) complètent le dispositif.
- Correspondances à retenir : mot de passe et pare-feu → confidentialité ; antivirus → intégrité et disponibilité ; sauvegarde → disponibilité.
- Aucune protection n'est absolue : la sécurité repose sur la combinaison des couches et sur la vigilance de l'utilisateur.

5 GESTION DES PROFILS ET PRIVILÈGES DES UTILISATEURS

Dans la section précédente, nous avons étudié les techniques de protection des données et des logiciels : antivirus, pare-feu, mots de passe robustes. Ces outils forment une première ligne de défense, mais ils ne suffisent pas. Imaginons le laboratoire informatique d'un lycée de Yaoundé : trente ordinateurs partagés entre les élèves, les enseignants et le personnel administratif. Si chacun pouvait tout faire sur chaque machine — installer des jeux, supprimer les fichiers des autres, modifier les paramètres réseau —, le système serait vite en panne et les données en danger. Il faut donc un mécanisme qui détermine **qui** a le droit de faire **quoi** sur le système. C'est précisément l'objet de la gestion des profils et des privilèges des utilisateurs, dernière brique essentielle de la sécurité informatique.

5.1 Compte utilisateur et ouverture de session

Situation de départ. Le matin, au laboratoire, chaque élève s'assoit devant un poste et tape un nom d'utilisateur puis un mot de passe. Pourquoi ce rituel ? Parce que le système d'exploitation doit d'abord identifier la personne (qui es-tu ?) puis vérifier son identité (prouve-le !) avant de lui donner accès à un environnement de travail personnel : ses dossiers, ses paramètres, ses

droits.

DÉFINITION Compte utilisateur

Un **compte utilisateur** est l'ensemble des informations associées à une personne (ou à un service) sur un système informatique : un **identifiant** (nom d'utilisateur, unique), un **mot de passe** (secret d'authentification), un répertoire personnel et des droits d'accès. Saisir son identifiant et son mot de passe pour accéder au système s'appelle **ouvrir une session** (ou se connecter) ; quitter le système proprement s'appelle **fermer la session**.

Le mot de passe est la clé du compte : il doit être robuste (au moins 8 caractères mêlant lettres, chiffres et symboles) et strictement personnel. Un compte se prête aussi peu qu'une carte d'identité : celui qui utilise ton compte agit en ton nom, et c'est toi qui seras tenu pour responsable de ses actes.

ATTENTION Erreur fréquente : partager son mot de passe

Dans beaucoup d'établissements, des élèves se communiquent leurs mots de passe « pour dépanner ». Conséquence : impossible de savoir qui a réellement supprimé le fichier ou publié le message insultant. La **traçabilité** des actions — un pilier de la sécurité — disparaît. Un mot de passe ne se partage jamais, pas même avec son meilleur ami.

5.2 Notion de privilège

Deux personnes connectées à la même machine ne peuvent pas forcément faire les mêmes choses : l'enseignant peut installer un logiciel, l'élève non. Ce qui les distingue, ce sont leurs privilèges.

DÉFINITION Privilège

Un **privilège** (ou **droit**) est un droit d'accès ou d'action accordé à un utilisateur sur un système informatique. Les privilèges typiques sont : lire un fichier, écrire ou modifier un fichier, supprimer un fichier, exécuter un programme, installer un logiciel, administrer le système (créer des comptes, modifier les paramètres).

Sur les systèmes de la famille Linux, ces droits se règlent finement, fichier par fichier, pour trois catégories de personnes : le propriétaire du fichier, son groupe, et les autres. La commande `ls -l` affiche ces droits sous la forme de neuf caractères : `r` (lecture), `w` (écriture), `x` (exécution).

```
$ ls -l bulletin_sequentiel.txt
-rw-r--r-- 1 mballa profs 2048 mars 12 08 :30 bulletin_sequentiel.txt
# -rw-r--r-- signifie :
# propriétaire (mballa) : lecture + écriture
# groupe (profs)       : lecture seule
```

autres (eleves...) : lecture seule

Ici, le professeur `mballa` peut modifier son bulletin ; ses collègues et les élèves peuvent seulement le consulter. Le système applique ces droits à chaque tentative d'accès : c'est le **contrôle d'accès**.

5.3 Les quatre profils d'utilisateurs

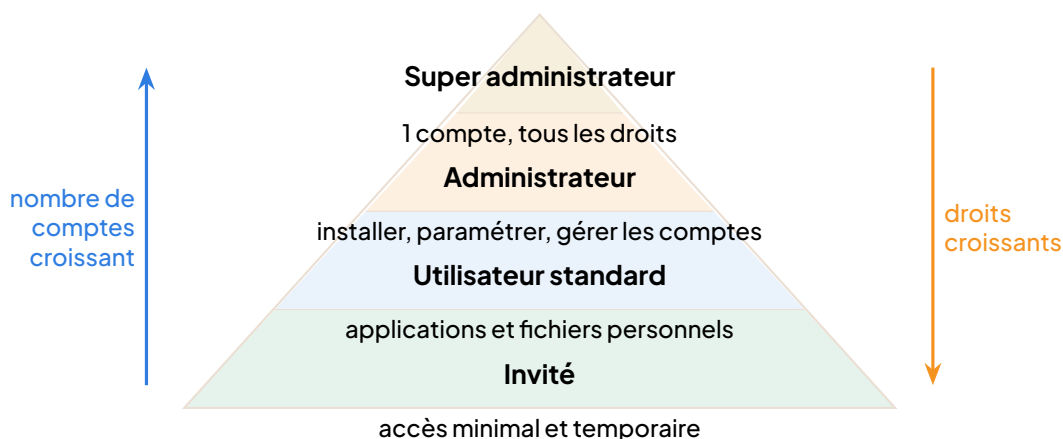
Plutôt que de régler les droits action par action pour chaque personne, les systèmes proposent des **profils** : des ensembles de privilèges prédéfinis, adaptés à des rôles types. Du plus puissant au plus limité, on distingue quatre profils.

Le super administrateur (root, super utilisateur). C'est le compte tout-puissant : il possède tous les droits sur le système, y compris la gestion des autres comptes (création, suppression, modification des mots de passe), l'accès à tous les fichiers et la modification des paramètres les plus sensibles. Un seul compte de ce type suffit, et il doit être réservé à un usage exceptionnel : installation du système, réparation, configuration initiale.

L'administrateur. Il peut installer et désinstaller des logiciels, modifier les paramètres du système (réseau, imprimantes, mises à jour) et gérer les utilisateurs ordinaires. C'est le profil du gérant de cybercafé, du professeur responsable du laboratoire ou du technicien informatique.

L'utilisateur standard. Il utilise les applications installées et travaille dans ses propres fichiers, mais ne peut ni installer de logiciel, ni modifier le système, ni toucher aux fichiers des autres. C'est le profil recommandé pour le travail quotidien, y compris pour un administrateur en dehors de ses tâches d'administration.

L'invité. Profil très limité et temporaire : il permet de consulter des documents ou de naviguer, sans rien installer, sans modifier les données des autres, et souvent sans laisser de trace après la fermeture de session. Idéal pour un visiteur de passage.



Pyramide des privilèges : plus on monte, plus les droits sont étendus — et plus le nombre de comptes doit être restreint.

Le tableau suivant compare les quatre profils sur quatre actions sensibles.

Profil	Installer un logiciel	Modifier le système	Créer des comptes	Fichiers des autres
Super administrateur	Oui	Oui	Oui	Oui
Administrateur	Oui	Oui	Oui	Selon réglages
Utilisateur standard	Non	Non	Non	Non
Invité	Non	Non	Non	Non

LESAVAIS-TU ? Root contre Administrateur

Sur les systèmes de la famille Linux (Ubuntu, Debian...), le super administrateur s'appelle **root** (la « racine ») ; pour exécuter ponctuellement une commande avec ses pouvoirs, on la fait précéder de `sudo` (superuser do). Sur Windows, le compte tout-puissant s'appelle **Administrateur**, et le système UAC (contrôle de compte d'utilisateur) demande une confirmation avant toute action sensible. Au Cameroun, la plupart des administrations et des entreprises utilisent Windows, mais les serveurs — y compris ceux des grands opérateurs télécoms — tournent massivement sous Linux.

5.4 Le principe du moindre privilège

Pourquoi ne pas donner le profil administrateur à tout le monde, « pour simplifier » ? Parce que chaque droit accordé en trop est une porte ouverte à une erreur ou à une attaque.

PROPRIÉTÉ Principe du moindre privilège — admise

Le **principe du moindre privilège** consiste à n'accorder à chaque utilisateur que les droits strictement nécessaires à l'accomplissement de ses tâches, ni plus, ni moins. Ce principe réduit la **surface d'attaque** d'un système : moins un compte a de droits, moins sa compromission (vol du mot de passe, logiciel malveillant exécuté dans la session) est dangereuse.

L'intérêt pour la sécurité est triple :

- **Limiter les dégâts d'une erreur humaine** : un utilisateur standard qui supprime par mégarde un fichier ne détruit que ses fichiers, pas le système ;
- **Limiter les dégâts d'un vol de compte** : le pirate qui vole le mot de passe d'un élève ne peut pas installer de logiciel espion sur tout le réseau ;
- **Limiter les dégâts d'un logiciel malveillant** : un virus s'exécute avec les droits de l'utilisateur qui l'a lancé ; lancé depuis une session standard, il ne peut pas s'installer en profondeur.

ATTENTION Erreur fréquente : travailler en administrateur au quotidien

Beaucoup d'utilisateurs travaillent chaque jour avec un compte administrateur « pour ne pas être embêtés ». C'est une faute grave : tout programme exécuté dans cette session — y compris un virus reçu par clé USB ou par hameçonnage — hérite de tous les droits et peut alors s'installer durablement, désactiver l'antivirus ou chiffrer les fichiers (rançongiciel). La bonne pratique : un compte standard pour le travail quotidien, et le compte administrateur réservé aux seules tâches d'administration.

MÉTHODE Comment attribuer les privilèges

Pour répartir correctement les profils dans un établissement :

1. Identifier les besoins réels de chaque utilisateur : quelles tâches doit-il accomplir ? Quels logiciels, quels dossiers ?
2. Choisir le profil minimal suffisant : le profil le plus faible qui permet quand même d'accomplir ces tâches ;
3. Créer les comptes avec des mots de passe robustes et distincts ;
4. Réviser régulièrement les droits accordés : un élève qui change de classe, un enseignant qui part, un stagiaire dont la mission s'achève doivent voir leurs droits ajustés ou leur compte désactivé.

EXEMPLE Dans un cybercafé de Douala

Dans un cybercafé, les clients utilisent un profil invité ou standard : ils naviguent, rédigent et impriment leurs documents, mais ne peuvent rien installer (donc pas de jeu piraté ni de logiciel espion) ni lire les fichiers laissés par le client précédent. Seul le gérant possède le compte administrateur, qu'il n'utilise que pour installer les mises à jour, gérer la facturation et nettoyer les postes. Résultat : les machines restent stables et les données des clients restent confidentielles.

5.5 Mise en situation : le réseau du laboratoire d'un lycée

Appliquons le principe du moindre privilège au laboratoire informatique du Lycée de Nkol-Eton. Quatre catégories de personnes utilisent les postes : le proviseur, les enseignants, les élèves et les visiteurs (inspecteurs, parents en visite).

EXERCICE RÉSOLU 5 Attribuer les profils du laboratoire

Énoncé. Le réseau du laboratoire compte 30 postes élèves, 1 poste enseignant et 1 serveur géré par le technicien. Attribue à chaque catégorie de personnes le profil le plus

adapté, en justifiant par le principe du moindre privilège : le proviseur, l'enseignant d'informatique (qui entretient les postes), les élèves, un inspecteur en visite.

SOLUTION

Solution détaillée. On applique la méthode : besoins réels, puis profil minimal suffisant.

- Le technicien / enseignant chargé de la maintenance : profil administrateur. Il doit installer les logiciels éducatifs, paramétrer le réseau et créer les comptes des élèves en début d'année. Le compte super administrateur du serveur reste unique, protégé par un mot de passe fort conservé sous scellé, et ne sert qu'aux opérations exceptionnelles.
- Le proviseur : profil utilisateur standard. Il consulte les bulletins, rédige des courriers et consulte ses courriels : aucun besoin d'installer des logiciels. Un profil plus élevé serait un risque inutile.
- Les enseignants (hors maintenance) : profil utilisateur standard, avec un droit d'écriture sur le dossier partagé « Notes » du serveur.
- Les élèves : profil utilisateur standard restreint : accès à leurs seuls fichiers personnels, interdiction d'installer des logiciels et de modifier les paramètres réseau. Ainsi, une fausse manœuvre ou un jeu infecté sur clé USB ne peut pas endommager le poste ni les fichiers des camarades.
- L'inspecteur en visite : profil invité, temporaire, sans accès aux dossiers de l'établissement, désactivé dès son départ.

Vérification du principe du moindre privilège : chaque catégorie dispose exactement des droits nécessaires à ses tâches, et aucune n'a de droit superflu. Si le mot de passe d'un élève est volé, le pirate hérite d'un compte quasi inoffensif ; si le poste du proviseur exécute un virus, celui-ci reste confiné à une session standard.

EXPÉRIENCE TP guidé : créer des comptes et observer les privilèges

Objectif : créer un compte standard et un compte invité, puis constater concrètement la différence de droits. Matériel : un poste Windows ou Linux avec un compte administrateur.

1. Ouvre une session avec le compte administrateur. Dans les paramètres des comptes d'utilisateurs, crée un compte standard nommé `e1eve1` avec un mot de passe robuste.
2. Ferme la session, puis ouvre une session `e1eve1`. Tente d'installer un petit logiciel : observe que le système exige le mot de passe d'un administrateur. Tente de modifier l'heure du système ou un paramètre réseau : même blocage.
3. Crée un fichier texte dans le dossier personnel de `e1eve1`. Rouvre la session administrateur et constate que ce fichier est rangé dans un répertoire propre à `e1eve1`.

4. Sous Linux, ouvre un terminal et exécute `ls -l /home` puis `whoami` ; tente `sudo apt update` depuis `e1eve1` et observe le refus.

Interprétation : le système applique les privilèges à chaque action ; le compte standard est confiné à son espace, ce qui illustre le principe du moindre privilège.

À RETENIR L'essentiel de la section

- Un **compte utilisateur** (identifiant + mot de passe) permet d'ouvrir une session ; un **privilège** est un droit d'accès ou d'action accordé à ce compte.
- Quatre profils : **super administrateur** (tous les droits, usage exceptionnel), **administrateur** (installer, paramétrer, gérer les comptes), **utilisateur standard** (travail quotidien), **invité** (accès minimal et temporaire).
- Le **principe du moindre privilège** : n'accorder que les droits strictement nécessaires, puis réviser régulièrement. Il limite les dégâts en cas d'erreur, de vol de compte ou de logiciel malveillant.
- On ne travaille jamais au quotidien avec un compte administrateur.

EXERCICE 3 À toi de jouer

Le secrétariat d'un lycée de Bafoussam gère les bulletins sur un ordinateur partagé entre la secrétaire, le censeur et un stagiaire de deux mois. Propose un profil pour chacun en justifiant, puis explique pourquoi le stagiaire ne doit surtout pas recevoir le mot de passe du compte administrateur.

CORRIGÉ Exercice n

La secrétaire saisit les notes et imprime les bulletins : profil utilisateur standard suffit, avec droit d'écriture sur le dossier « Bulletins ». Le censeur supervise et valide : profil utilisateur standard également (la validation ne demande pas d'installer de logiciels), avec droit de lecture sur tous les dossiers pédagogiques. Le stagiaire, présent deux mois pour classer des documents : profil invité ou standard très restreint, désactivé à la fin du stage. Lui donner le mot de passe administrateur violerait le principe du moindre privilège : il pourrait installer des logiciels (éventuellement malveillants), modifier ou supprimer les bulletins des autres, et son départ laisserait un accès dangereux non contrôlé. En cas d'erreur ou d'acte malveillant commis avec ce compte, il serait en outre impossible d'identifier le véritable auteur.

6 ACTIVITÉ D'INTÉGRATION

7 SÉCURITÉ INFORMATIQUE ET CYBERCRIMINALITÉ – ACTIVITÉ D'INTÉGRATION : AUDIT DU LABORATOIRE DE BONABÉRI

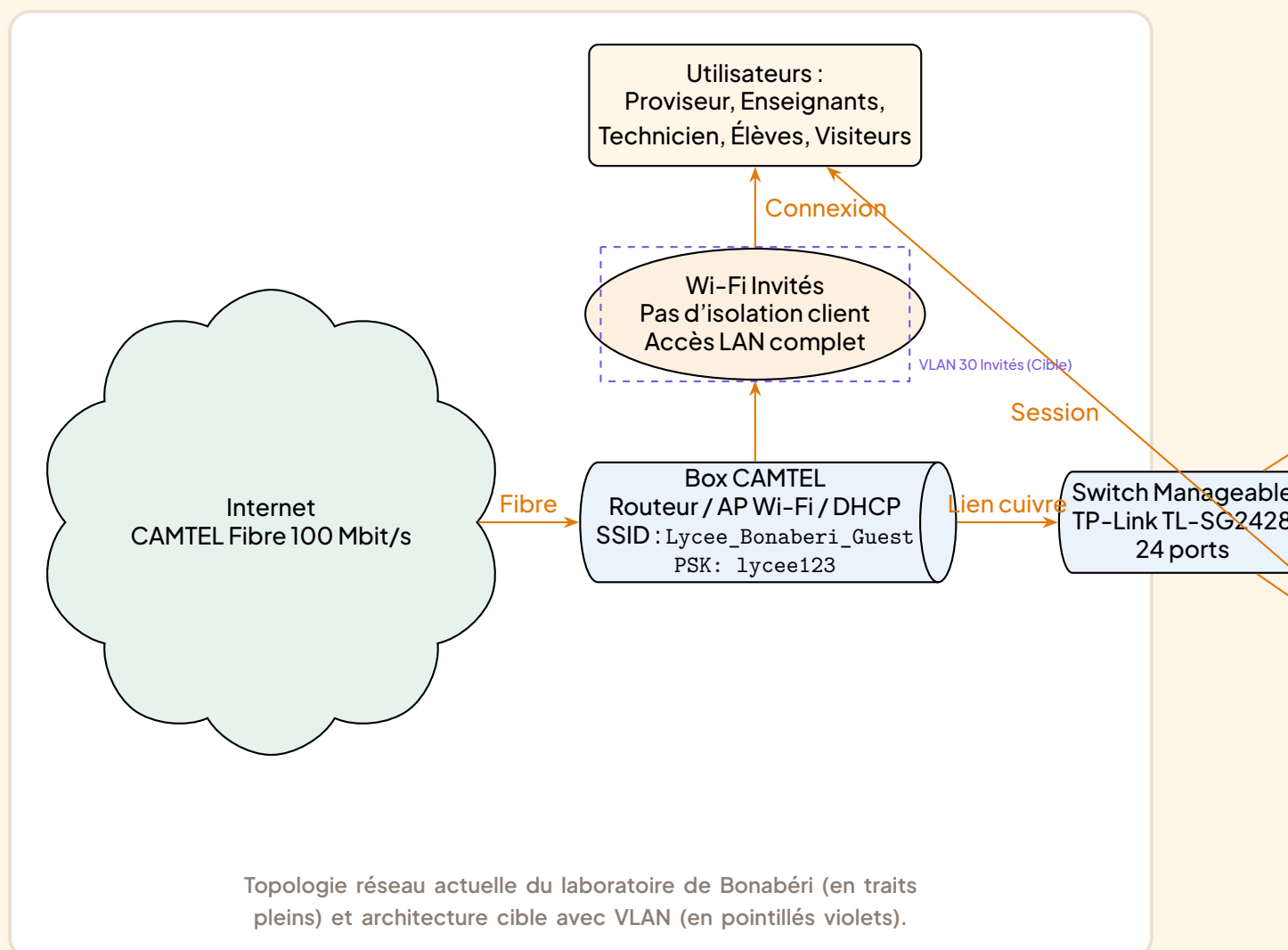
7.1 Objectifs de l'activité

Cette activité d'intégration vise à mobiliser l'ensemble des savoir-faire acquis au cours de la leçon sur la sécurité informatique et la cybercriminalité. À travers l'audit d'un laboratoire informatique réel, vous devrez être capable de :

- Identifier et classer des menaces concrètes selon la typologie des actes de cybercriminalité étudiée.
- Relier chaque menace aux piliers fondamentaux de la sécurité (**Confidentialité**, **Intégrité**, **Disponibilité**) qu'elle compromet.
- Concevoir un plan de protection technique et organisationnel (antivirus, pare-feu, politique de mots de passe).
- Définir une matrice de privilèges adaptée aux différents profils d'utilisateurs d'un établissement scolaire.
- Argumenter vos choix techniques avec un vocabulaire précis et rigoureux.

7.2 Situation : Audit de sécurité du laboratoire informatique du Lycée Bilingue de Bonabéri

Le proviseur du Lycée Bilingue de Bonabéri (Douala) vous mandate, en tant qu'experts juniors en sécurité informatique, pour réaliser un audit de sécurité de la salle multimédia. Cette salle est utilisée pour les cours d'informatique (séries C, D, E), les travaux de recherche documentaire (CDI) et les inscriptions en ligne (Parcoursup, bourses MINESUP).



Configuration matérielle et logicielle actuelle :

- **Parc** : 20 postes de travail fixes (HP ProDesk 400 G6, Windows 10 Pro 21H2) interconnectés par un switch manageable 24 ports (TP-Link TL-SG2428) relié à la box fibre CAMTEL (100 Mbit/s symétrique).
- **Comptes utilisateurs** : Un unique compte local AdminLabo (mot de passe : AdminLabo2024) dispose des droits d'administrateur sur les 20 machines. Ce compte est connu de tous les élèves et affiché sur un pense-bête collé sur le bureau du poste n°1 (poste « maître »). Aucun compte élève individualisé n'existe.
- **Protection logicielle** : Windows Defender est actif mais les définitions de virus datent de 8 mois (pas de connexion automatique aux mises à jour Windows Update depuis une erreur de configuration du proxy). Aucun antivirus tiers n'est installé. Le pare-feu Windows est en mode « Public » mais la règle « Partage de fichiers et d'imprimantes » est autorisée pour tout le réseau.
- **Réseau Wi-Fi** : La box CAMTEL émet un SSID `Lycee_Bonaberi_Guest`. Le mot de passe WPA2-PSK est `lycee123`, écrit en gros au feutre sur le tableau blanc de la salle. Le réseau invité n'est pas isolé du réseau filaire (pas de VLAN, pas de Client Isolation).

- **Données sensibles** : Un dossier partagé \\POSTE1\Notes_Bulletins (accessible en lecture/écriture par Everyone) contient les fichiers Excel des moyennes trimestrielles de toutes les classes de Première. Une clé USB non chiffrée, branchée en permanence sur le poste n°1, sert de « sauvegarde » quotidienne (copier-coller manuel).

Incident récent : Mme Ngo, enseignante de mathématiques, a reçu hier sur sa messagerie professionnelle (prenom.nom@lycee-bonaberi.cm) un courriel dont l'objet était : « **URGENT : Mise à jour de vos identifiants bancaires CAMPOST / SCB** ». L'expéditeur affiché était service.client@scb-cam (adresse visuellement proche de l'officielle). Le corps du mail, reprenant le logo de la Société Camerounaise de Banque, invitait à cliquer sur un lien <http://scb-cameroun-securite.cm/maj> pour « réactiver son compte bloqué ». Mme Ngo a failli cliquer, mais l'URL suspecte (domaine .cm au lieu de .com, sous-domaine étrange) l'a alertée. Elle a signalé le mail au technicien de maintenance, qui n'a pas encore réagi.

Contexte humain :

- **Proviseur / Administration** : Besoin d'accéder aux bulletins, aux effectifs, aux dossiers administratifs. Doit déléguer la gestion technique.
- **Enseignants (15)** : Préparent les cours, saisissent les notes, consultent des ressources pédagogiques en ligne. Compétences informatiques hétérogènes.
- **Technicien de maintenance (1)** : Seul personnel technique. Gère le parc, les mises à jour, le réseau. Doit avoir la main sur tout le matériel.
- **Élèves (environ 800, rotation par groupes de 40)** : Utilisent la salle pour les TP (programmation C, HTML/JS, bureautique), recherches internet. Certains tentent d'installer des jeux, de contourner les restrictions ou d'accéder aux dossiers partagés.
- **Visiteurs / Inspecteurs / Parents (occasionnels)** : Accès Wi-Fi pour consultation rapide (messagerie, site MINESUP). Ne doivent pas voir le réseau interne.

7.3 Consignes

Travaillant en groupe de 4, répondez aux questions suivantes en vous appuyant sur les connaissances de la leçon. Chaque réponse doit être justifiée.

1. **Identification et classification des menaces** : Dressez la liste exhaustive des vulnérabilités et menaces présentes dans la situation. Pour chacune, indiquez le type d'acte de cybercriminalité correspondant (vol d'identité, vol de mot de passe, intrusion non autorisée, publication de faux documents ; craquage de mot de passe, déni de service, hameçonnage/phishing, ingénierie sociale).
2. **Analyse par les piliers CIA** : Pour chaque menace identifiée à la question 1, précisez quel(s) pilier(s) de la sécurité informatique (Confidentialité, Intégrité, Disponibilité) est/sont directement menacé(s). Justifiez en une phrase.
3. **Plan de protection technique** : Proposez un plan d'action concret et priorisé (court terme / moyen terme) pour sécuriser le laboratoire. Il doit inclure :
 - La stratégie antivirus (choix, déploiement, mise à jour).

- La configuration du pare-feu (règles entrantes/sortantes, isolation du poste maître).
 - La politique de mots de passe : définissez les critères de robustesse (longueur, complexité, expiration) et proposez un mot de passe robuste pour le compte administrateur technique et pour le Wi-Fi (donnez des exemples concrets respectant vos critères).
 - La sécurisation du partage de fichiers (droits NTFS, suppression du partage « Everyone »).
 - La sauvegarde (règle 3-2-1, chiffrement).
4. **Gestion des profils et privilèges (Matrice des droits)** : Établissez un tableau formel attribuant les profils (Super Administrateur, Administrateur, Utilisateur standard / Élève, Invité) aux acteurs (Proviseur, Enseignant, Technicien, Élève, Visiteur). Pour chaque couple (Acteur, Profil), listez 3 privilèges accordés et 3 privilèges refusés/interdits. Justifiez le choix du profil par rapport au principe du moindre privilège.
5. **Sensibilisation** : Proposez 3 actions de sensibilisation concrètes à destination des enseignants et des élèves pour prévenir le hameçonnage et l'ingénierie sociale, en lien avec l'incident de Mme Ngo.

7.4 Ressources à mobiliser

- **Triade CIA** : **Confidentialité** (accès autorisé seulement), **Intégrité** (données exactes, non modifiées par tiers), **Disponibilité** (services accessibles quand nécessaire).
- **Actes de cybercriminalité (programme)** : Vol d'identité, vol de mot de passe, intrusion non autorisée, publication de faux documents, craquage de mot de passe (force brute, dictionnaire), déni de service (DoS), hameçonnage/phishing, ingénierie sociale.
- **Protections techniques** : Antivirus (signatures, heuristique, temps réel), Pare-feu (filtrage stateful, règles par défaut « deny all », DMZ), Mots de passe (entropie, gestionnaire, MFA si possible).
- **Profils Windows / Active Directory** : Administrateurs (contrôle total), Utilisateurs (exécution apps, pas d'install, pas de modif système), Invités (accès très limité, profil temporaire). Principe du moindre privilège (Least Privilege).
- **Règle 3-2-1 de sauvegarde** : 3 copies, 2 supports différents, 1 hors site (ou hors ligne).

7.5 Démarche et corrigé commenté

EXERCICE RÉSOLU 6

Audit de sécurité du Lycée Bilingue de Bonabéri – Corrigé type

Question 1 – Identification et classification des menaces



Question 2 – Analyse par les piliers CIA

Menace	Pilier(s) menacé(s)	Justification
Vol mot de passe / Intrusion admin	Confidentialité, Intégrité, Disponibilité	C : accès aux données admin/élèves. I : modification scripts, notes, logs. D : désactivation antivirus, arrêt services, chiffrement disque (ransomware).
Antivirus obsolète	Intégrité, Disponibilité	I : injection code malveillant, modification fichiers système. D : ransomware chiffre données, plante OS. (C indirect si exfiltration).
Pare-feu / Partage ouvert	Confidentialité, Intégrité	C : lecture fichiers notes, listes élèves. I : écriture/suppression dans partage.
Wi-Fi non sécurisé	Confidentialité, Intégrité, Disponibilité	C : écoute trafic non chiffré (HTTP, SMB). I : injection paquets, ARP spoofing. D : flood DHCP, déauthentification.
Dossier notes « Everyone »	Confidentialité, Intégrité	C : consultation notes camarades. I : falsification moyennes (corruption données).
Clé USB unique non chiffrée	Confidentialité, Disponibilité	C : vol physique = fuite notes. D : perte/panne = perte totale historique.
Phishing (Mme Ngo)	Confidentialité, Intégrité	C : vol identifiants bancaires/professionnels. I : si compte compromis, envoi mails frauduleux depuis son adresse (usurpation).

Question 3 – Plan de protection technique (Priorisé)

A. Court terme (Immédiat – Semaine 1) – « Stop the bleeding »

1. Changement immédiat des secrets :

- **Compte admin technique** : renommer en `TechAdmin_LB24`, mot de passe robuste `K7#mP9$vL2qW4!` (16 caractères, 4 classes : maj, min, chiffre, spécial). Stocké dans KeePass (gestionnaire) sur clé USB du technicien uniquement.
- **Wi-Fi** : Nouveau PSK WPA2-PSK (ou WPA3 si box compatible) : `Lyc3e_B0nab3r1_W1f1_2025#Secu` (28 caractères, phrase de passe complexe). Affiché uniquement sur demande au technicien, pas au tableau. Activer Client Isolation (AP Isolation) sur la box.

2. **Antivirus** : Déployer un antivirus gratuit gérable (ex : Bitdefender Free ou Kaspersky Free ou maintenir Windows Defender à condition de forcer la mise à jour des définitions via script PowerShell quotidien + configuration proxy correcte). Activer Protection en temps réel, Protection cloud, Contrôle dossiers contrôlés (anti-ransomware).
3. **Partage Notes_Bulletins** : Casser l'héritage. Droits NTFS : Technicien (Contrôle total), Enseignants_Notes (Groupe : Modification), Administration (Lecture), Élèves (Aucun). Supprimer le partage « Everyone ». Activer l'audit (Succès/Échec) sur écriture.
4. **Sauvegarde** : Arrêter la clé USB branchée. Mettre en place script robocopy journalier vers un NAS (ou 2ème disque interne dédié sur poste maître) chiffré BitLocker + copie hebdo sur disque dur externe hors site (bureau proviseur). Vérification de restauration mensuelle.

B. Moyen terme (Mois 1-2) – « Durcissement »

1. **Pare-feu Windows** (GPO locale ou domaine si AD) : Règle par défaut : Entrant : Bloquer, Sortant : Autoriser. Créer règles Entrant Autoriser uniquement pour : RDP (port 3389) uniquement depuis IP Technicien, SMB (445) uniquement depuis IP Poste Maître + IP Serveur NAS, ICMPv4 (Ping) depuis IP Technicien. Bloquer tout le reste.
2. **Comptes utilisateurs** : Créer des comptes locaux standard pour les élèves (ex : Eleve_TP01 à Eleve_TP40, mdp initial unique `Ch@ng3M3#2025` forcé au 1er logon) ou, mieux, déployer un contrôleur de domaine Samba/AD (si budget/compétences) pour comptes nominatifs. Désactiver le compte AdminLabo natif.
3. **Stratégie de mots de passe** (GPO) : Longueur min 12, complexité activée, âge max 90 jours, historique 5, verrouillage compte 5 essais / 15 min.
4. **Segmentation réseau (VLAN)** : VLAN 10 (Admin/Profs), VLAN 20 (Élèves filaire), VLAN 30 (Wi-Fi Invités). Routage inter-VLAN filtré par pare-feu (switch L3 ou routeur). Élèves n'accèdent pas VLAN 10.
5. **Durcissement poste maître** : Désactiver ports USB inutilisés (GPO), désactiver Auto-Play, activer BitLocker sur disque système et disque données.

Question 4 – Matrice des profils et privilèges (Principe du moindre privilège)



Justification globale : Le technicien a besoin de contrôle total sur la machine (OS, matériel, réseau) mais pas sur la donnée métier (notes, paie) → séparation d'administration technique et fonctionnelle. Le proviseur gère l'établissement, pas l'OS. Les enseignants sont des utilisateurs métiers avancés. Les élèves sont en environnement cloisonné (kiosque durci). Les visiteurs sont isolés en DMZ Wi-Fi.

Question 5 – Sensibilisation (3 actions concrètes)

1. Atelier « Chasse au Phishing » (1h, vie de classe) : Analyse collective de l'email reçu par Mme Ngo. Identifier 5 indices : (1) Expéditeur vs domaine réel (scb.cm vs scb-cameroun-securite.cm), (2) Urgence artificielle, (3) Lien affiché ≠ lien réel (survol souris), (4) Demande d'identifiants (banque ne demande jamais par mail), (5) Pièce jointe .exe/.zip suspecte. Règle d'or : Ne jamais cliquer, signaler au technicien, supprimer.
2. Affichage permanent dans la salle (A3 plastifié) : « STOP – Réfléchis avant de cliquer
1. Connais-tu l'expéditeur réellement ?
2. Y a-t-il urgence ou menace ?
3. L'URL commence-t-elle par https:// et le domaine est-il exact ?
4. On ne donne jamais son mot de passe par mail/téléphone.
Signaler : technicien@lycee-bonaberi.cm ».
3. Charte de bon usage signée (Rentrée) : Chaque élève/enseignant signe une charte incluant : « Je m'engage à ne pas partager mes identifiants, à verrouiller ma session (Win+L), à ne pas brancher de périphérique personnel non scanné, à signaler tout comportement suspect ». Rappel sanctions (règlement intérieur + loi n°2010/012 sur la cybercriminalité au Cameroun).

SOLUTION

Commentaires pédagogiques pour l'enseignant :

- Question 1 : Attendez-vous à ce que les élèves confondent « vulnérabilité » (faiblesse) et « menace » (danger potentiel). Corrigez : « L'antivirus obsolète est une vulnérabilité ; le ransomware qui en profite est la menace. » Valorisez les groupes qui citent le typosquattage pour le domaine bancaire.
- Question 2 : Le piège classique est de cocher les 3 piliers pour tout. Exigez la nuance : le phishing vise d'abord la **Confidentialité** (vol identifiants), l'**Intégrité** vient après (usurpation). Le partage « Everyone » vise l'**Intégrité** (falsif) et la **Confidentialité** (lecture), pas la **Disponibilité** (le fichier reste là).
- Question 3 : Vérifiez que les mots de passe proposés respectent l'entropie (ex : 12+ chars, 4 classes). Refusez « LyceeBonaberi2025! » (dictionnaire + pattern). Exigez la règle 3-2-1 explicitement citée. La segmentation VLAN est un « plus » niveau Terminale, mais accessible en 1ère comme culture réseau.
- Question 4 : Le tableau est le cœur de l'évaluation. Vérifiez la cohérence : un Élève n'a jamais droit à `cmd` ou `regedit`. Un Visiteur n'a jamais accès au LAN (SMB/RDP). Le Pro-

viseur n'est pas Super Admin. Le Technicien n'est pas gestionnaire de notes.

- Question 5 : L'action doit être applicable demain sans budget. L'affiche et l'atelier coûtent 0 FCFA. La charte engage la responsabilité.

7.6 Bilan de l'activité

Cet audit a permis de mettre en évidence, par la pratique, l'indissociabilité des dimensions technique, organisationnelle et humaine de la sécurité informatique.

- **Technique** : Une faille unique (mot de passe admin partagé, antivirus mort, partage ouvert) compromet instantanément les trois piliers CIA. La défense en profondeur (antivirus + pare-feu + droits NTFS + sauvegarde chiffrée + VLAN) n'est pas un luxe mais une nécessité vitale, même pour un « petit » laboratoire de 20 postes.
- **Organisationnelle** : La gestion des identités (un compte par personne, profils adaptés) est la pierre angulaire. Le principe du moindre privilège n'est pas une contrainte administrative mais une barrière de confinement : si le compte élève est compromis, le dégât s'arrête à son profil.
- **Humaine** : L'incident de Mme Ngo prouve que le maillon le plus faible reste l'utilisateur. La meilleure technologie (pare-feu, antivirus) ne protège pas contre un clic sur un lien de phishing bien ficelé. La formation continue, la signalisation d'incidents sans culpabilisation et les réflexes de vérification (URL, expéditeur, urgence) sont la dernière ligne de défense.
- **Contexte camerounais** : La dépendance à la box FAI (CAMTEL/MTN/Orange) comme unique équipement réseau impose de maîtriser son interface d'administration (changement PSK, isolation client, DMZ, DNS). La loi n°2010/012 criminalise l'accès frauduleux, l'interception de données et la falsification de documents informatiques : l'audit n'est pas seulement pédagogique, il est légal.

Vous avez maintenant une vision systémique : **Protéger, c'est Prévoir, Cloisonner, Surveiller et Former**. C'est cette compétence globale que le Probatoire et, plus tard, le monde professionnel (BTS, Licence, ingénierie) attendent de vous.

8 MÉTHODES ET EXERCICES RÉSOLUS

9 SÉCURITÉ INFORMATIQUE ET CYBERCRIMINALITÉ

9.1 Méthode 1 : Définir les concepts fondamentaux de la sécurité informatique

MÉTHODE Définir et distinguer confidentialité, intégrité et disponibilité

Pour définir correctement les trois piliers de la sécurité informatique (le triptyque **CID**), suis la démarche suivante :

1. Commence par donner la définition générale : la **sécurité informatique** est l'ensemble des moyens techniques, organisationnels et humains mis en œuvre pour protéger les systèmes d'information contre les menaces.
2. Définis chaque pilier en une phrase précise, en utilisant le vocabulaire exact du programme :
 - **Confidentialité** : seules les personnes autorisées peuvent accéder aux données ;
 - **Intégrité** : les données ne peuvent être ni modifiées ni détruites de manière non autorisée ; elles restent exactes et complètes ;
 - **Disponibilité** : les données et les services doivent être accessibles aux utilisateurs autorisés au moment où ils en ont besoin.
3. Associe à chaque pilier un exemple concret et, si possible, la menace qui le vise (écoute indiscreète → confidentialité ; falsification d'un document → intégrité ; déni de service → disponibilité).
4. Ne confonds jamais les trois : une même attaque peut viser plusieurs piliers, mais chaque pilier répond à une question distincte : qui voit ?, est-ce intact ?, est-ce accessible ?.

EXERCICE RÉSOLU 7 Les trois piliers du CID

Énoncé. Le lycée de Nkongsamba numérise les bulletins de ses élèves. Le proviseur souhaite sécuriser ce nouveau service. (a) Définis la sécurité informatique. (b) Définis ses trois piliers fondamentaux et indique, pour chacun, un risque concret auquel le lycée est exposé.

SOLUTION

Solution détaillée.

(a) La **sécurité informatique** est l'ensemble des moyens techniques, organisationnels et humains mis en œuvre pour protéger un système d'information (matériels, logiciels, données) contre les menaces accidentelles ou intentionnelles, afin de garantir la confidentialité, l'intégrité et la disponibilité des informations.

(b) Les trois piliers fondamentaux, appelés triptyque **CID**, sont :

- Confidentialité : seules les personnes autorisées peuvent accéder aux données. Risque concret : un élève ou une personne étrangère au lycée consulte les notes d'un autre élève, par exemple en utilisant le mot de passe d'un enseignant.
- Intégrité : les données ne doivent pas être modifiées ou détruites de manière non autorisée ; elles doivent rester exactes et complètes. Risque concret : un élève s'introduit dans le système et modifie ses notes de mathématiques avant l'impression des bulletins.
- Disponibilité : les données et les services doivent être accessibles aux utilisateurs autorisés au moment où ils en ont besoin. Risque concret : le jour de la remise des bulletins, le serveur est en panne ou victime d'une attaque par déni de service, et les bulletins ne peuvent plus être imprimés.

Conclusion. Sécuriser le service du lycée consiste donc à garantir simultanément que les notes ne sont lues que par les personnes habilitées (confidentialité), qu'elles ne sont pas falsifiées (intégrité) et qu'elles restent accessibles au moment voulu (disponibilité).

9.2 Méthode 2 : Définir cybercriminalité et cybersécurité

MÉTHODE Définir et opposer cybercriminalité et cybersécurité

1. Définis la **cybercriminalité** comme l'ensemble des infractions (actes illégaux) commises par l'intermédiaire des réseaux informatiques, notamment Internet, ou visant un système informatique. Précise toujours l'auteur : le **cybercriminel**.
2. Définis la **cybersécurité** comme l'ensemble des lois, politiques, techniques et bonnes pratiques destinées à protéger les systèmes, les réseaux et les données contre les cyberattaques.
3. Mets en évidence l'opposition : la cybercriminalité est la menace (l'attaque), la cybersécurité est la réponse (la défense). L'une est un délit, l'autre une discipline de protection.
4. Situe le contexte : au Cameroun, la loi n° 2010/012 du 21 décembre 2010 relative à la cybersécurité et à la cybercriminalité réprime ces actes ; citer ce repère valorise ta

copie.

EXERCICE RÉSOLU 8 Cybercriminalité ou cybersécurité ?

Énoncé. Un individu envoie à des clients d'une banque de Douala de faux messages les invitant à communiquer leurs codes bancaires. L'ANTIC (Agence Nationale des Technologies de l'Information et de la Communication) mène l'enquête et sensibilise les populations aux bonnes pratiques. (a) Définis la cybercriminalité et la cybersécurité. (b) Dans cette situation, identifie ce qui relève de la cybercriminalité et ce qui relève de la cybersécurité.

SOLUTION

Solution détaillée.

(a) La **cybercriminalité** est l'ensemble des infractions pénales commises au moyen d'un réseau informatique (notamment Internet) ou visant un système informatique : vol de données, escroquerie en ligne, intrusion, etc. La **cybersécurité** est l'ensemble des moyens juridiques, techniques, organisationnels et humains mis en œuvre pour protéger les systèmes d'information, les réseaux et les données contre ces attaques.

(b) Analysons la situation élément par élément :

- L'envoi de faux messages pour soutirer les codes bancaires des clients est un acte illégal commis via un réseau informatique : il relève de la cybercriminalité (il s'agit précisément d'hameçonnage, associé à une tentative de vol d'identité bancaire).
- L'enquête de l'ANTIC et la sensibilisation des populations aux bonnes pratiques sont des mesures de protection et de lutte contre ces actes : elles relèvent de la cybersécurité.

Conclusion. Dans cette situation, l'attaque (faux messages) illustre la cybercriminalité, tandis que la réaction des autorités (enquête, prévention) illustre la cybersécurité : la première est la menace, la seconde est la défense.

9.3 Méthode 3 : Identifier et énumérer les actes de cybercriminalité

MÉTHODE Reconnaître un acte de cybercriminalité à partir d'une description

1. Lis attentivement la situation et repère les éléments caractéristiques : ce qui est visé (identité, mot de passe, système, réputation), le moyen utilisé (faux message, logiciel, ruse psychologique) et le résultat (vol, blocage, falsification).
2. Associe la situation au bon acte en te servant du tableau de correspondance :

Acte	Élément caractéristique
Vol d'identité	Usurpation de l'identité d'une personne (nom, photos, comptes) pour agir à sa place
Vol de mot de passe	Récupération frauduleuse des identifiants d'un utilisateur
Craquage de mot de passe	Deviner un mot de passe par essais répétés (force brute, dictionnaire)
Intrusion non autorisée	Pénétration dans un système sans droit d'accès
Publication de faux documents	Diffusion de documents falsifiés (faux diplômes, fausses attestations)
Déni de service (DoS)	Saturation d'un serveur pour le rendre indisponible
Hameçonnage (phishing)	Faux message / faux site imitant un organisme officiel pour soutirer des données
Ingénierie sociale	Manipulation psychologique d'une personne pour qu'elle révèle elle-même des informations confidentielles

3. Justifie toujours ta réponse en citant l'élément de l'énoncé qui permet l'identification : c'est la justification qui rapporte le point.
4. Distingue bien vol (on te prend ton mot de passe à ton insu), craquage (on le devine par calcul) et hameçonnage (on te le fait donner volontairement par ruse).

EXERCICE RÉSOLU 9 Identifier les actes de cybercriminalité

Énoncé. Pour chacune des situations suivantes, identifie l'acte de cybercriminalité commis et justifie ta réponse.

- a. Sandrine reçoit un SMS prétendument envoyé par son opérateur mobile lui demandant de cliquer sur un lien et de saisir son code Mobile Money pour « débloquer son compte ».
- b. Un programme teste automatiquement des milliers de combinaisons pour deviner le mot de passe du compte administrateur d'un cybercafé de Bafoussam.
- c. Un inconnu appelle la secrétaire d'une entreprise en se faisant passer pour le technicien de maintenance et lui demande le mot de passe du serveur « pour une mise à jour urgente ».
- d. Le site web d'une université devient inaccessible pendant les inscriptions en ligne car des milliers de machines envoient simultanément des requêtes vers son serveur.

SOLUTION

Solution détaillée.

a. Hameçonnage (phishing). Le message imite un organisme officiel (l'opérateur mobile) et utilise un faux prétexte (« débloquer son compte ») pour inciter la victime à communiquer volontairement son code confidentiel. C'est exactement la définition de l'hameçonnage, associé ici à une tentative de vol de mot de passe.

b. Craquage de mot de passe. Le programme teste des milliers de combinaisons de manière automatique : c'est la technique de la force brute (ou attaque par dictionnaire), qui caractérise le craquage de mot de passe. Il ne s'agit pas d'un vol, car rien n'est subtilisé directement : le mot de passe est deviné par calcul.

c. Ingénierie sociale. L'attaquant n'utilise aucun outil technique : il exploite la confiance et la crédulité de la secrétaire en se faisant passer pour un technicien (manipulation psychologique) afin qu'elle révèle elle-même le mot de passe. C'est la signature de l'ingénierie sociale.

d. Déni de service (DoS). Le serveur est saturé par un nombre massif de requêtes simultanées, ce qui le rend indisponible pour les utilisateurs légitimes (les étudiants qui veulent s'inscrire). L'attaque vise le pilier disponibilité : c'est un déni de service (distribué, car plusieurs machines participent).

Conclusion. Chaque acte se reconnaît à son mécanisme : la ruse par faux message (hameçonnage), le calcul exhaustif (craquage), la manipulation humaine (ingénierie sociale) et la saturation (déni de service).

9.4 Méthode 4 : Décrire les techniques de protection des données

MÉTHODE Décrire antivirus, pare-feu et mot de passe

1. Pour chaque technique, donne : sa définition, son rôle (ce qu'elle protège) et son mode de fonctionnement en une ou deux phrases.
2. Retiens le schéma suivant :
 - **Antivirus** : logiciel qui détecte, bloque et supprime les programmes malveillants (virus, vers, chevaux de Troie) en analysant les fichiers et en comparant leurs signatures à sa base de données ; il doit être régulièrement mis à jour pour rester efficace.
 - **Pare-feu** (firewall) : dispositif logiciel ou matériel placé entre un réseau interne et l'extérieur, qui filtre le trafic entrant et sortant selon des règles prédéfinies et bloque les accès non autorisés.
 - **Mot de passe** : code secret d'authentification qui vérifie l'identité de l'utilisateur ; pour être robuste, il doit être long (au moins 8 caractères), complexe (majuscules, minuscules, chiffres, symboles), unique et changé régulièrement.

3. Précise toujours ce que chaque technique ne fait pas : un antivirus ne filtre pas le réseau, un pare-feu ne supprime pas les virus, un mot de passe seul ne protège pas contre l'ingénierie sociale. La protection efficace est complémentaire (défense en profondeur).
4. Tu peux compléter par d'autres techniques vues en cours : sauvegardes régulières, chiffrement des données, mises à jour du système, authentification à deux facteurs.

EXERCICE RÉSOLU 10 Protéger le poste d'une boutique

Énoncé. M. Etoundi gère la comptabilité de sa boutique d'Ebolowa sur un ordinateur connecté à Internet. Il a déjà perdu des fichiers à cause d'un virus et craint que des inconnus accèdent à ses données via le réseau. Décris trois techniques de protection adaptées à sa situation, en précisant pour chacune son rôle et son fonctionnement.

SOLUTION

Solution détaillée.

1. L'antivirus. C'est un logiciel qui détecte, bloque et supprime les programmes malveillants (virus, vers, chevaux de Troie). Il analyse les fichiers du disque et ceux téléchargés, et compare leurs signatures à une base de données de menaces connues. Adaptation à la situation : il répond directement au problème de perte de fichiers par virus. Condition d'efficacité : sa base de signatures doit être mise à jour régulièrement, sinon les virus récents passent inaperçus.
2. Le pare-feu. C'est un dispositif logiciel ou matériel qui filtre le trafic réseau entrant et sortant selon des règles prédéfinies, en autorisant les communications légitimes et en bloquant les accès non autorisés. Adaptation à la situation : placé entre l'ordinateur et Internet, il empêche les inconnus d'accéder aux données comptables via le réseau, ce qui répond exactement à la crainte exprimée.
3. Le mot de passe. C'est un code secret qui authentifie l'utilisateur, c'est-à-dire qui vérifie son identité avant de lui donner accès au poste ou à un logiciel. Pour être robuste, le mot de passe de M. Etoundi doit comporter au moins 8 caractères mêlant majuscules, minuscules, chiffres et symboles (par exemple éviter 12345 ou sa date de naissance), être différent pour chaque compte et être changé régulièrement. Adaptation à la situation : il garantit la confidentialité des données même si une personne a physiquement accès à l'ordinateur.

Conclusion. Ces trois techniques sont complémentaires : l'antivirus protège contre les programmes malveillants, le pare-feu contre les intrusions réseau, et le mot de passe contre les accès physiques ou logiques non autorisés. M. Etoundi peut y ajouter des sauvegardes régulières de ses fichiers comptables pour garantir leur disponibilité.

9.5 Méthode 5 : Attribuer les privilèges aux utilisateurs

MÉTHODE Choisir le bon profil d'utilisateur

1. Recense les trois profils classiques et leurs droits :
 - **Super administrateur** : tous les droits sur le système, y compris la gestion des autres administrateurs ; réservé au responsable technique principal ;
 - **Administrateur** : installe et désinstalle les logiciels, configure le système, crée et gère les comptes utilisateurs ;
 - **Invité** (ou utilisateur simple) : droits limités, utilise les applications et consulte ses propres fichiers, sans pouvoir modifier la configuration ni installer de logiciels.
2. Applique le principe du moindre privilège : à chaque utilisateur, n'accorde que les droits strictement nécessaires à ses tâches. C'est la règle d'or de la gestion des profils.
3. Pour attribuer un profil dans une situation donnée, pose-toi deux questions : quelle tâche cette personne doit-elle accomplir ? et quel est le niveau de droits minimal pour l'accomplir ?
4. Justifie toujours ton choix par la tâche de l'utilisateur, jamais par son statut social ou son ancienneté.

EXERCICE RÉSOLU 11 Attribuer les profils dans un lycée

Énoncé. Le réseau informatique d'un lycée de Bertoua comprend un serveur géré par M. Abena, informaticien de l'établissement. Les enseignants saisissent les notes, et les élèves consultent leurs bulletins dans la salle multimédia. (a) Cite les trois profils d'utilisateurs étudiés en classe. (b) Attribue à chaque acteur (M. Abena, un enseignant, un élève) un profil en justifiant ton choix.

SOLUTION

Solution détaillée.

(a) Les trois profils d'utilisateurs sont : le **super administrateur**, l'**administrateur** et l'**invité** (utilisateur à droits limités).

(b) Attribution des profils, selon le principe du moindre privilège (n'accorder que les droits nécessaires aux tâches de chacun) :

- M. Abena (informaticien) : profil administrateur (voire super administrateur s'il est le seul responsable technique). Justification : il doit installer les logiciels, configurer le serveur, créer et gérer les comptes des enseignants et des élèves ; ces tâches exigent les droits d'administration.
- Un enseignant : profil utilisateur avec droits spécifiques (compte standard doté de l'accès à l'application de saisie des notes). Justification : sa tâche se limite à saisir et

consulter les notes de ses classes ; il n'a pas besoin d'installer des logiciels ni de modifier la configuration du serveur. Lui donner les droits d'administrateur exposerait le système à des erreurs de manipulation ou à des abus.

- Un élève : profil invité. Justification : l'élève doit uniquement consulter son bulletin ; le profil invité, aux droits très limités (pas d'installation, pas de modification de la configuration, accès restreint à ses propres données), suffit largement et protège le système contre les manipulations malveillantes ou maladroites.

Conclusion. En appliquant le principe du moindre privilège, le lycée garantit que chaque acteur dispose exactement des droits dont il a besoin : administration pour M. Abena, saisie pour les enseignants, simple consultation pour les élèves, ce qui renforce la confidentialité et l'intégrité des données scolaires.

9.6 Méthode 6 : Analyser un scénario complet de sécurité (synthèse)

MÉTHODE Rédiger une analyse de sécurité en quatre temps

Face à un sujet de synthèse (« sécurisez le système d'information de... »), structure ta réponse ainsi :

1. Identifier les biens à protéger : données (notes, comptes clients), matériels (serveurs, postes), services (site web, messagerie).
2. Identifier les menaces : pour chaque bien, cite l'acte de cybercriminalité plausible (intrusion, hameçonnage, déni de service...) et le pilier du CID menacé (confidentialité, intégrité, disponibilité).
3. Proposer les contre-mesures : associer à chaque menace une technique de protection adaptée (antivirus, pare-feu, mot de passe robuste, sauvegardes, gestion des profils, sensibilisation des utilisateurs).
4. Conclure par la complémentarité des mesures : aucune technique seule ne suffit ; la sécurité repose sur la combinaison de moyens techniques et humains (formation, vigilance face à l'ingénierie sociale).

Présente idéalement les étapes 2 et 3 sous forme de tableau menace → pilier visé → protection : c'est clair, rapide et très apprécié du correcteur.

EXERCICE RÉSOLU 12 Sécuriser le système d'information d'un cybercafé

Énoncé. Mme Fotso ouvre un cybercafé à Yaoundé avec dix postes en réseau, un serveur de fichiers et une connexion Internet. Elle craint les virus apportés par les clés USB des clients, les accès indésirables à sa caisse informatisée et l'indisponibilité du réseau.

Construis un tableau récapitulatif menace / pilier visé / technique de protection, puis rédige une conclusion de quatre lignes maximum.

SOLUTION

Solution détaillée.

Étape 1 — Biens à protéger : les données de la caisse (recettes), les postes clients, le serveur de fichiers et l'accès Internet.

Étapes 2 et 3 — Menaces et contre-mesures :

Menace	Pilier visé	Technique de protection
Virus introduits par les clés USB des clients	Intégrité (et disponibilité)	Antivirus à jour sur chaque poste, analyse automatique des périphériques amovibles
Accès non autorisé à la caisse informatisée (intrusion, vol de mot de passe)	Confidentialité	Mot de passe robuste et unique, compte administrateur réservé à Mme Fotso, profil invité pour les clients
Attaques venant d'Internet (intrusion via le réseau)	Confidentialité, intégrité	Pare-feu filtrant le trafic entrant et sortant
Panne ou attaque par déni de service rendant le réseau inutilisable	Disponibilité	Sauvegardes régulières, matériel de secours, filtrage du trafic anormal par le pare-feu
Manipulation des employés ou clients (ingénierie sociale)	Confidentialité	Sensibilisation : ne jamais communiquer un mot de passe, verrouiller la session en s'absentant

Étape 4 — Conclusion. La sécurité du cybercafé repose sur la complémentarité des moyens : l'antivirus protège l'intégrité des postes, le pare-feu et les mots de passe garantissent la confidentialité de la caisse, les sauvegardes assurent la disponibilité des données, et la gestion des profils (administrateur pour la patronne, invité pour les clients) limite les droits de chacun. Aucune technique ne suffit seule : la vigilance humaine reste indispensable, car l'utilisateur est souvent le maillon faible du système.

ATTENTION Les 5 erreurs qui coûtent des points au Bac

1. Confondre les piliers du CID. Dire qu'un déni de service menace la confidentialité est

faux : il menace la disponibilité. Avant de répondre, demande-toi : l'attaque vise-t-elle à lire (confidentialité), à modifier (intégrité) ou à bloquer (disponibilité) ?

2. Confondre vol, craquage et hameçonnage de mot de passe. Le vol se fait à l'insu de la victime, le craquage consiste à deviner par essais répétés (force brute), l'hameçonnage consiste à faire donner le mot de passe volontairement par un faux message. Citer le mauvais terme, même avec une bonne intuition, fait perdre le point.
3. Définir sans illustrer ni justifier. Une définition récitée sans exemple concret tiré de l'énoncé, ou une identification d'acte sans citation de l'élément qui la justifie, ne rapporte qu'une partie des points. Justifie toujours : « il s'agit de... car l'énoncé précise que... ».
4. Présenter une technique de protection comme suffisante. Écrire « l'antivirus protège totalement l'ordinateur » est une erreur : l'antivirus ne filtre pas le réseau et devient inefficace s'il n'est pas mis à jour. Mentionne toujours les conditions d'efficacité et la complémentarité des protections.
5. Attribuer les privilèges selon le statut et non selon la tâche. Donner le profil administrateur au directeur « parce qu'il est le chef » viole le principe du moindre privilège : on attribue les droits selon les tâches à accomplir, pas selon la hiérarchie sociale. Un directeur qui ne fait que consulter des rapports n'a besoin que d'un compte utilisateur.

10 EXERCICES

10.1 Je vérifie mes connaissances

EXERCICE 4 QCM : les piliers de la sécurité informatique

Pour chaque question, choisir la bonne réponse (une seule réponse correcte par question).

1. Les trois piliers fondamentaux de la sécurité informatique sont :
 - a) rapidité, confidentialité, ergonomie ;
 - b) confidentialité, intégrité, disponibilité ;
 - c) antivirus, pare-feu, mot de passe ;
 - d) authentification, compression, sauvegarde.
2. Le pilier de la sécurité qui garantit que les données n'ont pas été modifiées de manière non autorisée est :
 - a) la confidentialité ;
 - b) la disponibilité ;
 - c) l'intégrité ;
 - d) l'authenticité.
3. Le hameçonnage (phishing) consiste à :
 - a) saturer un serveur de requêtes pour le rendre inaccessible ;
 - b) se faire passer pour un organisme de confiance afin de dérober des informations personnelles ;
 - c) essayer toutes les combinaisons possibles pour trouver un mot de passe ;
 - d) chiffrer les fichiers d'une victime contre rançon.
4. Le profil d'utilisateur qui possède tous les droits sur le système, y compris la gestion des autres administrateurs, est :
 - a) l'invité ;
 - b) l'utilisateur standard ;
 - c) l'administrateur ;
 - d) le super administrateur.

EXERCICE 5 Vrai ou faux, à justifier

Répondre par vrai ou faux, puis justifier la réponse en une ou deux phrases.

1. « Un antivirus à jour suffit à garantir la sécurité totale d'un ordinateur. »
2. « Le pare-feu a pour rôle principal de détecter et de supprimer les virus présents sur le disque dur. »
3. « Le compte invité peut installer un logiciel sur la machine. »

4. « L'ingénierie sociale exploite la confiance et la crédulité des personnes plutôt que les failles techniques des logiciels. »

EXERCICE 6 Définitions

Définir chacun des termes suivants en deux lignes maximum :

1. cybercriminalité ;
2. cybersécurité ;
3. déni de service (DoS) ;
4. vol d'identité.

EXERCICE 7 Association : acte, définition, pilier menacé

Recopier et compléter le tableau suivant en associant à chaque acte de cybercriminalité sa définition et le pilier de la sécurité (confidentialité, intégrité ou disponibilité) principalement menacé.

Acte	Définition	Pilier menacé
Hameçonnage	...	...
Déni de service	...	...
Vol d'identité	...	...
Craquage de mot de passe	...	...
Publication de faux documents	...	...

10.2 Je m'entraîne

EXERCICE 8 Le SMS frauduleux

Moussa, élève en classe de Première D, reçoit le SMS suivant : « Votre compte Momo sera bloqué dans 24 h. Pour éviter le blocage, envoyez votre code PIN au 6XX XX XX XX. »

1. Identifier l'acte de cybercriminalité dont Moussa est la cible.
2. Expliquer en quelques phrases le mécanisme de cette attaque.
3. Rédiger la conduite à tenir pour Moussa (au moins trois actions concrètes).
4. Citer le pilier de la sécurité informatique qui serait compromis si Moussa répondait au

message.

EXERCICE 9 Robustesse des mots de passe

Voici cinq mots de passe utilisés dans un cybercafé de Yaoundé :

123456 ; yaounde ; Yaounde2024 ; Y@ound3_2024! ; azerty

1. Classer ces mots de passe du plus faible au plus robuste en justifiant chaque choix (longueur, diversité des caractères, présence dans les dictionnaires).
2. À partir de la phrase personnelle « Je réussirai mon Probatoire en 2025 à Ebolowa », construire un mot de passe robuste en expliquant la méthode utilisée.
3. Citer deux bonnes pratiques de gestion des mots de passe (en dehors de leur complexité).

EXERCICE 10 Privilèges des profils utilisateurs

Recopier et compléter le tableau ci-dessous en cochant (X) les actions autorisées pour chaque profil d'utilisateur d'un système d'exploitation.

Action	Super admin.	Admin.	Utilisateur standard	Invité
Installer un logiciel				
Créer et supprimer des comptes utilisateurs				
Modifier les paramètres système				
Lire et modifier ses propres fichiers				
Gérer les autres administrateurs				

Justifier ensuite pourquoi il est déconseillé de travailler quotidiennement avec un compte administrateur.

EXERCICE 11 Protection d'un poste de travail

Le lycée de Bafoussam vient d'équiper sa salle multimédia de 20 ordinateurs connectés à Internet.

1. Citer trois techniques de protection des données et des logiciels que le responsable informatique doit mettre en place sur chaque poste.
2. Pour chaque technique citée, décrire en une phrase son rôle précis.
3. Expliquer pourquoi la mise à jour régulière du système d'exploitation et des logiciels fait partie des mesures de protection.

10.3 Je me prépare au Probatoire

EXERCICE 12 Attaque contre la plateforme de notes d'un lycée

Le lycée classique de Ngaoundéré utilise une plateforme en ligne permettant aux parents de consulter les notes de leurs enfants. Pendant 48 heures, la plateforme est totalement inaccessible : le serveur reçoit des millions de requêtes simultanées envoyées par un réseau d'ordinateurs infectés, ce qui l'empêche de répondre aux utilisateurs légitimes. L'enquête révèle par ailleurs qu'un élève avait tenté, quelques jours plus tôt, de deviner le mot de passe du compte administrateur en testant de nombreuses combinaisons.

1. Nommer l'attaque qui a rendu la plateforme inaccessible et décrire précisément son mécanisme.
2. Indiquer le pilier de la sécurité informatique atteint par cette attaque, en justifiant.
3. Nommer la technique utilisée par l'élève pour tenter de s'emparer du mot de passe de l'administrateur.
4. Proposer trois mesures de prévention concrètes que l'administrateur réseau du lycée peut mettre en œuvre pour éviter qu'un tel incident ne se reproduise.
5. Le proviseur souhaite que chaque enseignant ne puisse saisir que les notes de sa propre matière, sans pouvoir modifier la configuration de la plateforme. Quel type de profil utilisateur faut-il attribuer aux enseignants ? Justifier.

EXERCICE 13 Sécurité dans un cybercafé de Douala

Mme Etoundi gère un cybercafé à Bonabéri. Ses clients utilisent les ordinateurs pour consulter leurs comptes bancaires en ligne, imprimer des documents et accéder à leurs réseaux sociaux. Récemment, plusieurs clients se sont plaints : l'un a découvert que ses identifiants de messagerie avaient été dérobés après avoir cliqué sur un lien reçu par courriel imitant sa banque ; un autre a constaté que des documents officiels falsifiés circulaient en son nom sur les réseaux sociaux.

1. Identifier les deux actes de cybercriminalité subis par les clients de Mme Etoundi et

définir chacun d'eux.

2. Pour chaque acte, indiquer le ou les piliers de la sécurité informatique compromis.
3. Expliquer ce qu'est l'ingénierie sociale et montrer en quoi elle intervient dans le premier cas décrit.
4. Mme Etoundi veut sécuriser son cybercafé. Proposer une configuration des profils utilisateurs adaptée : quel profil pour elle-même, quel profil pour ses clients ? Justifier chaque choix.
5. Rédiger une affiche de quatre conseils de prudence à destination des clients du cybercafé.

EXERCICE 14 Problème de synthèse : la bibliothèque numérique

Dans le cadre de la modernisation de ses services, la bibliothèque d'un collège de Buea met en place un système de prêt informatisé. Le documentaliste dispose d'un compte lui permettant de gérer les livres et les emprunts ; les élèves disposent d'un compte leur permettant uniquement de consulter le catalogue et leurs propres emprunts ; un compte de maintenance, utilisé par le prestataire informatique, permet d'installer les mises à jour du logiciel. Un jour, un élève reçoit un appel téléphonique d'une personne se faisant passer pour un technicien de la mairie, qui lui demande de communiquer le mot de passe du documentaliste « pour une vérification urgente ».

1. Définir la cybersécurité et expliquer en quoi elle diffère de la cybercriminalité.
2. Identifier la technique d'attaque utilisée lors de l'appel téléphonique et expliquer son principe.
3. Indiquer la conduite à tenir pour l'élève qui reçoit cet appel.
4. Associer à chacun des trois comptes décrits dans l'énoncé le profil utilisateur correspondant (super administrateur, administrateur, utilisateur standard, invité) en justifiant.
5. Citer deux équipements ou logiciels de protection que le collège doit installer sur son réseau, et préciser le rôle de chacun.
6. Expliquer pourquoi la confidentialité et l'intégrité des données de la bibliothèque sont toutes deux importantes, en donnant un exemple de dommage concret pour chaque pilier.

11 CORRIGÉS DES EXERCICES

CORRIGÉ Exercice 1 — QCM : les piliers de la sécurité informatique

1. Réponse b) : les trois piliers fondamentaux de la sécurité informatique sont la **confidentialité**, l'**intégrité** et la **disponibilité** (triade CID). La réponse c) cite des techniques de protection et non des piliers.
2. Réponse c) : l'**intégrité** garantit que les données sont exactes et complètes, c'est-à-dire qu'elles n'ont subi aucune modification non autorisée.
3. Réponse b) : le hameçonnage est une fraude qui consiste à se faire passer pour un organisme de confiance (banque, opérateur, administration) afin de dérober des informations personnelles. La réponse a) décrit un déni de service et la réponse c) un craquage de mot de passe par force brute.
4. Réponse d) : le **super administrateur** possède tous les droits, y compris la gestion des autres comptes administrateurs.

CORRIGÉ Exercice 2 — Vrai ou faux, à justifier

1. Faux. L'antivirus ne détecte que les menaces qu'il connaît ; il doit être complété par un pare-feu, des mises à jour régulières, des mots de passe robustes et surtout un comportement prudent de l'utilisateur. La sécurité totale n'existe pas.
2. Faux. Le pare-feu filtre les communications réseau entrantes et sortantes (il autorise ou bloque les connexions) ; c'est l'antivirus qui détecte et supprime les virus sur le disque dur.
3. Faux. Le compte invité possède des droits très limités : il permet de consulter des documents et d'utiliser les applications installées, mais pas d'installer de logiciels ni de modifier les paramètres du système.
4. Vrai. L'ingénierie sociale est une technique de manipulation psychologique : l'attaquant abuse de la confiance, de la peur ou de la crédulité de la victime (faux appel, faux message urgent) pour lui soutirer des informations, sans exploiter de faille logicielle.

CORRIGÉ Exercice 3 — Définitions

1. Cybercriminalité : ensemble des infractions pénales commises au moyen d'un sys-

tème informatique ou d'un réseau, ou visant un tel système (vols, fraudes, intrusions, destructions de données).

2. Cybersécurité : ensemble des moyens techniques, organisationnels et humains mis en œuvre pour protéger les systèmes, les réseaux et les données contre les attaques et les menaces numériques.
3. Déni de service (DoS) : attaque qui consiste à saturer un serveur ou un réseau de requêtes afin de le rendre inaccessible aux utilisateurs légitimes.
4. Vol d'identité : acte qui consiste à s'approprier les informations personnelles d'une personne (nom, numéros, identifiants) pour se faire passer pour elle et commettre des fraudes en son nom.

CORRIGÉ**Exercice 4 — Association : acte, définition, pilier menacé**

Acte	Définition	Pilier menacé
Hameçonnage	Se faire passer pour un organisme de confiance afin de dérober des informations personnelles (identifiants, codes, données bancaires).	Confidentialité
Déni de service	Saturer un serveur de requêtes pour le rendre inaccessible aux utilisateurs légitimes.	Disponibilité
Vol d'identité	S'approprier les informations personnelles d'une personne pour se faire passer pour elle.	Confidentialité
Craquage de mot de passe	Découvrir un mot de passe en testant de nombreuses combinaisons (dictionnaire, force brute).	Confidentialité
Publication de faux documents	Créer et diffuser des documents falsifiés au nom d'une personne ou d'une institution.	Intégrité

Remarque : certains actes menacent plusieurs piliers à la fois ; on indique ici le pilier principalement atteint, comme le demande l'énoncé.

CORRIGÉ Exercice 5 — Le SMS frauduleux

1. Il s'agit d'un **hameçonnage** (phishing), ici par SMS (on parle parfois de smishing), qui repose sur l'**ingénierie sociale**.
2. Le fraudeur se fait passer pour l'opérateur de mobile money, crée un sentiment d'urgence (« bloqué dans 24 h ») pour affoler la victime et la pousse à révéler son code PIN. Une fois le code obtenu, il peut vider le compte de la victime.
3. Conduite à tenir : ne jamais répondre ni communiquer son code PIN (aucun opérateur ne le demande par SMS) ; supprimer le message et bloquer le numéro ; vérifier l'information en appelant le service client officiel de l'opérateur ; signaler le numéro frauduleux à l'opérateur et en parler à un adulte ou à un enseignant.
4. Le pilier compromis serait la **confidentialité** : le code PIN, information secrète, serait divulgué à une personne non autorisée.

CORRIGÉ Exercice 6 — Robustesse des mots de passe

1. Classement du plus faible au plus robuste :
 - 123456 : suite numérique triviale, la première combinaison testée par les attaquants ;
 - azerty : suite de touches du clavier, présente dans tous les dictionnaires d'attaque ;
 - yaounde : mot du dictionnaire, en minuscules uniquement, facile à deviner ;
 - Yaounde2024 : plus long et mélangeant majuscules et chiffres, mais construit sur un mot du dictionnaire suivi d'une année prévisible ;
 - Y@ound3_2024! : le plus robuste : 13 caractères, majuscules, minuscules, chiffres, caractères spéciaux et substitutions qui éloignent le mot du dictionnaire.
2. Méthode de la phrase mnémotechnique : on prend la première lettre de chaque mot de la phrase « Je réussirai mon Probatoire en 2025 à Ebolowa », ce qui donne JrmPe2aE, puis on ajoute des substitutions et un caractère spécial : par exemple JrmP3_2aE! . Le mot de passe est long, varié, sans rapport direct avec un mot du dictionnaire, et facile à mémoriser grâce à la phrase.
3. Bonnes pratiques : ne jamais réutiliser le même mot de passe sur plusieurs comptes ; ne jamais noter son mot de passe sur un papier visible ni le communiquer à quiconque ; changer régulièrement ses mots de passe ; verrouiller sa session dès qu'on s'éloigne du poste.

CORRIGÉ Exercice 7 — Privilèges des profils utilisateurs

Action	Super admin.	Admin.	Utilisateur standard	Invité
Installer un logiciel	X	X		
Créer et supprimer des comptes utilisateurs	X	X		
Modifier les paramètres système	X	X		
Lire et modifier ses propres fichiers	X	X	X	X
Gérer les autres administrateurs	X			

Travailler quotidiennement avec un compte administrateur est dangereux : tout programme exécuté (y compris un logiciel malveillant téléchargé par mégarde) hérite alors des droits d'administration et peut modifier le système en profondeur, installer d'autres programmes ou supprimer des fichiers essentiels. Une erreur de manipulation de l'utilisateur a également des conséquences beaucoup plus graves. On réserve donc le compte administrateur aux seules tâches d'administration et l'on utilise un compte standard au quotidien.

CORRIGÉ Exercice 8 — Protection d'un poste de travail

1. Trois techniques de protection : un **antivirus**, un **pare-feu** et des **mots de passe** robustes associés à des profils utilisateurs.
2. Rôles précis :
 - l'antivirus détecte, bloque et supprime les logiciels malveillants (virus, vers, chevaux de Troie) présents ou tentant de s'installer sur le poste ;
 - le pare-feu filtre les communications réseau entrantes et sortantes et bloque les connexions non autorisées ;
 - les mots de passe contrôlent l'accès aux comptes : seuls les utilisateurs autorisés peuvent ouvrir une session et accéder à leurs données.
3. Les mises à jour corrigent les failles de sécurité découvertes dans le système et les logiciels. Un poste non mis à jour conserve des vulnérabilités connues que les attaquants exploitent facilement ; mettre à jour régulièrement revient donc à fermer ces portes d'entrée.

CORRIGÉ Exercice 9 — Attaque contre la plateforme de notes d'un lycée

1. Il s'agit d'une attaque par **déni de service distribué** (DDoS) : un réseau d'ordinateurs infectés envoie simultanément des millions de requêtes vers le serveur, qui, submergé, ne peut plus traiter les demandes des utilisateurs légitimes.
2. Le pilier atteint est la **disponibilité** : le service existe toujours et les données ne sont ni lues ni modifiées, mais la plateforme est inaccessible pendant 48 heures.
3. L'élève a pratiqué le **craquage de mot de passe** (par force brute ou à l'aide d'un dictionnaire) : il teste de nombreuses combinaisons jusqu'à trouver la bonne.
4. Mesures de prévention possibles : installer et configurer un pare-feu capable de filtrer et de limiter les requêtes suspectes ; imposer des mots de passe robustes et bloquer temporairement un compte après quelques tentatives de connexion échouées ; maintenir à jour le serveur et ses logiciels ; effectuer des sauvegardes régulières et surveiller les journaux de connexion pour détecter les comportements anormaux.
5. Il faut attribuer aux enseignants un profil d'**utilisateur standard** : il permet d'utiliser l'application (saisir les notes de sa matière) sans donner accès à la configuration de la plateforme ni à la gestion des comptes, qui restent réservées à l'administrateur.

CORRIGÉ Exercice 10 — Sécurité dans un cybercafé de Douala

1. Premier acte : le **hameçonnage** (phishing) — le client a été trompé par un faux courriel imitant sa banque, qui l'a conduit à révéler ses identifiants. Deuxième acte : la **publication de faux documents** (associée à un vol d'identité) — des documents falsifiés sont diffusés au nom du client.
2. Le hameçonnage compromet la **confidentialité** (des identifiants secrets sont dérobés). La publication de faux documents compromet l'**intégrité** (des informations fausses circulent à la place de documents authentiques) et, par l'usurpation d'identité, touche aussi la confidentialité des données personnelles.
3. L'**ingénierie sociale** est une technique de manipulation psychologique qui exploite la confiance, la peur ou la crédulité des personnes pour leur soutirer des informations, sans attaquer directement les logiciels. Dans le premier cas, le faux courriel imite la banque (confiance) et pousse le client à cliquer et à saisir ses identifiants : c'est l'humain qui est trompé, pas la machine.
4. Pour elle-même, Mme Etoundi utilise un compte **administrateur** (ou super administrateur) : elle doit installer les logiciels, gérer les comptes et configurer les postes. Pour les clients, elle crée un compte **invité** (ou utilisateur standard très limité) : les clients peuvent naviguer et imprimer, mais ne peuvent ni installer de logiciels malveillants, ni modifier les paramètres, ni accéder aux données des autres utilisateurs.

5. Affichette : « Chers clients, pour votre sécurité : 1) Ne communiquez jamais vos mots de passe ou codes PIN, même à un proche ou à un prétendu employé de banque. 2) Vérifiez toujours l'adresse du site avant de saisir vos identifiants. 3) Fermez votre session et vos comptes (messagerie, réseaux sociaux) avant de quitter le poste. 4) Ne cliquez pas sur les liens des courriels ou SMS inattendus : en cas de doute, demandez conseil à la gérante. »

CORRIGÉ Exercice 11 — Problème de synthèse : la bibliothèque numérique

1. La **cybersécurité** est l'ensemble des moyens techniques, organisationnels et humains mis en œuvre pour protéger les systèmes, les réseaux et les données contre les menaces numériques. Elle se distingue de la **cybercriminalité**, qui désigne au contraire les infractions commises par voie informatique : la cybercriminalité est l'attaque, la cybersécurité est la défense.
2. L'appel téléphonique relève de l'**ingénierie sociale** : l'attaquant se fait passer pour un technicien (abus de confiance) et invoque une urgence pour pousser la victime à révéler un mot de passe, sans exploiter aucune faille technique.
3. L'élève doit refuser de communiquer le moindre mot de passe (un vrai technicien ne le demande jamais), raccrocher, puis signaler immédiatement l'appel au documentaliste ou à un enseignant afin que l'incident soit vérifié et consigné.
4. Attribution des profils :
 - compte de maintenance du prestataire : **administrateur** (ou super administrateur), car l'installation des mises à jour exige des droits d'administration ; ce compte ne doit être utilisé que pour la maintenance ;
 - compte du documentaliste : **utilisateur standard** doté des droits applicatifs nécessaires à la gestion des livres et des emprunts, sans pouvoir modifier la configuration du système ;
 - comptes des élèves : **invité** (ou utilisateur standard très limité), car ils ne font que consulter le catalogue et leurs propres emprunts.
5. Deux protections : un **pare-feu**, qui filtre les communications du réseau et bloque les connexions non autorisées ; un **antivirus**, qui détecte et supprime les logiciels malveillants sur les postes. On peut ajouter l'authentification par mots de passe robustes et les sauvegardes régulières des données.
6. La **confidentialité** garantit que seules les personnes autorisées accèdent aux données : si elle est violée, un élève indiscret peut consulter les emprunts ou les informations personnelles d'un camarade. L'**intégrité** garantit que les données sont exactes et non modifiées : si elle est violée, un emprunt peut être effacé ou falsifié, et un livre rendu apparaîtra comme non restitué, ce qui peut conduire à sanctionner un élève innocent.

12 FICHE BILAN

12.1 Carte mentale de la leçon



Carte mentale récapitulative de la leçon : les sept branches essentielles à maîtriser.

12.2 L'essentiel à retenir

FICHE BILAN L'essentiel à connaître pour l'examen

Définitions clés

- **Sécurité informatique** : ensemble des moyens techniques, organisationnels et humains mis en œuvre pour protéger les systèmes d'information contre les menaces.
- **Confidentialité** : seules les personnes autorisées accèdent aux données.
- **Intégrité** : les données sont exactes, complètes et non altérées.
- **Disponibilité** : les données et services restent accessibles aux utilisateurs légitimes quand ils en ont besoin.
- **Cybercriminalité** : ensemble des infractions (actes malveillants) commises par le biais des technologies de l'information et de la communication.
- **Cybersécurité** : ensemble des lois, politiques, outils et bonnes pratiques destinés à lutter contre la cybercriminalité et à protéger les systèmes d'information.

Actes de cybercriminalité à connaître

Acte	Description
Vol d'identité	Usurpation des informations personnelles d'une victime pour agir en son nom.
Vol / craquage de mot de passe	Obtention ou devinette (force brute, dictionnaire) d'un mot de passe.
Intrusion non autorisée	Pénétration illégale dans un système ou un réseau.
Publication de faux documents	Création et diffusion de documents falsifiés (faux bulletins, fausses attestations).
Déni de service (DoS)	Saturation d'un serveur pour le rendre indisponible : atteinte à la disponibilité .
Hameçonnage (phishing)	Faux message ou faux site imitant un organisme officiel pour voler des identifiants.
Ingénierie sociale	Manipulation psychologique d'une personne pour lui soutirer des informations confidentielles.

Techniques de protection

- **Antivirus** : détecte, bloque et élimine les logiciels malveillants ; à mettre à jour régulièrement.
- **Pare-feu** (firewall) : filtre le trafic réseau entrant et sortant selon des règles de sécurité.
- **Mot de passe** robuste : au moins 8 caractères, mélange de majuscules, minuscules, chiffres et symboles ; jamais communiqué ni réutilisé.
- Compléments : mises à jour du système, sauvegardes régulières, chiffrement des données sensibles.

Profil et privilèges des utilisateurs

- **Super administrateur** : tous les droits, y compris la gestion des autres administrateurs (souvent le compte `root` sous GNU/Linux).
- **Administrateur** : installe les logiciels, gère les comptes et les paramètres du système.
- **Invité** : droits très limités, aucune installation ni modification du système.

Méthode express : face à une menace, toujours raisonner en trois questions : quelle donnée est visée ? Quel pilier (C, I ou D) est menacé ? Quelle protection (antivirus, pare-feu, mot de passe, droits) y répond ?

À RETENIR Checklist avant le Bac

- ☐ Je sais définir la sécurité informatique et citer ses trois piliers : confidentialité, intégrité, disponibilité.
- ☐ Je sais associer chaque pilier à un exemple concret (ex. déni de service → disponibilité).
- ☐ Je sais définir la cybercriminalité et la cybersécurité sans les confondre.
- ☐ Je sais énumérer au moins six actes de cybercriminalité vus au programme.
- ☐ Je sais expliquer le principe de l'hameçonnage et de l'ingénierie sociale.
- ☐ Je sais décrire le rôle d'un antivirus et celui d'un pare-feu.
- ☐ Je sais énoncer les règles d'un mot de passe robuste.
- ☐ Je sais distinguer les privilèges du super administrateur, de l'administrateur et de l'invité.
- ☐ Je sais proposer une protection adaptée à une situation concrète (cybercafé, bulletin en ligne, compte bancaire).
- ☐ Je sais citer des bonnes pratiques : mises à jour, sauvegardes, méfiance face aux liens et pièces jointes inconnus.



Signé • OnBuch+

Ludovic A.
CONFORME AU PROGRAMME OFFICIEL MINESEC

OnBuch+